

发票数据管理系统

应用安全检测报告

初测

委托单位：东风汽车集团有限公司

测试人员：安全测试组

测试日期：2026年07月04日

东风汽车集团有限公司

检测概述

背景介绍

发票数据管理系统(FP)是东风汽车面向发票数据采集、查询、统计与管理的业务系统，提供发票查询(增值税发票/进项发票/机动车发票汇总等)、统计分析、基础数据与系统管理等功能。系统通过 10.124.9.253:443/fp/ 对外提供服务(承载于 HTTP，非 TLS)，前端采用 Vue 3 + Vite + Element Plus 单页架构，后端基于 RuoYi(Spring Boot/Spring Cloud 微服务)，接口前缀 /prod-api，经 nginx/1.21.5 反向代理。

为评估该平台的安全防护能力，识别潜在安全风险，依据国家标准和行业安全规范，对该平台开展全面的应用安全检测。本次检测结合黑盒渗透测试和灰盒测试(使用提供的管理员和普通用户测试账号)，从外部攻击者视角评估平台的安全态势。

参考标准

- 《OWASP 安全测试指南 V4.0》
- 《OWASP TOP10》
- 《GBT22239-2019 信息安全技术网络安全等级保护基本要求》
- 《ISO/IEC 27001 信息安全管理》
- 《数据安全法》
- 《个人信息保护法》

适用说明

针对发票数据管理系统(发票查询/统计分析/基础数据/系统管理等模块)开展应用安全检测，覆盖 Web 应用安全、API 安全、数据安全、认证授权等维度。

检测内容

该检测报告覆盖端口安全、基线安全、前端安全、传输安全、身份鉴别、权限管理、会话安全、密钥安全、异常处理、业务安全、日志审计、数据安全、常见漏洞等 13 个大类，共计 59 项安全检测内容。

注: 原模板 60 项中的 VULN-021(未授权浏览)已合并至 VULN-015(未授权访问)统一检测，二者检测内容完全一致，故实际检测 59 项。

检测工具

工具名称	工具类型	工具用途
cURL	接口测试	命令行 HTTP 客户端，API 安全测试、CORS 验证、安全头检测
OpenSSL	协议检测	SSL/TLS 协议版本、证书链、加密套件检测
Chrome DevTools/CDP	前端分析	前端代码分析、网络请求监控、DOM 审计
Playwright	自动化测试	浏览器自动化登录测试、Token 捕获、认证流程验证
Python 脚本	自动化测试	密码加密算法逆向分析、自动化安全检测脚本

风险评级标准

风险等级	定义	整改时限
------	----	------

严重	可直接获取系统控制权或大规模数据泄露,无需认证即可利用	24 小时内
高危	可获取敏感数据或绕过关键安全控制,利用条件较低	72 小时内
中危	存在安全隐患但利用需一定条件,或影响有限	2 周内
低危	安全加固建议,风险较小或需复杂利用条件	1 个月内

说明: 本报告中"风险等级"指该检测项的固有风险级别(即如果不符合时的严重程度), 与"测试结果"是两个独立维度。例如某项"风险等级=高危"且"测试结果=符合", 表示该领域属于高风险类别但系统已通过检测; 反之"风险等级=中危"且"测试结果=不符合", 表示该中等风险领域存在问题需要修复。

整改优先级建议

优先级	对应检测项	风险等级	整改说明
P0-立即修复	FRON-002, KEY-001, VULN-016, DATA-002	严重	前端硬编码 RSA 私钥(512 位)+发票敏感数据全字段明文,24 小时内修复
P1-紧急修复	AUTH-001, SESS-002, VULN-006, DATA-001, VULN-001, DATA-003, BUS-002, AUTH-010, TRAN-002	高危	验证码关闭+CORS 反射任意源+全站 HTTP 明文+敏感数据导出+CSRF,72 小时内修复
P2-72 小时	AUTH-003, SESS-001, SESS-004, TRAN-001, VULN-014	中危	MFA 未启用+会话/传输版本信息,2 周内修复
P3-计划修复	VULN-020	中危	URL 开放重定向,1 个月内修复

变更记录

版本	日期	变更内容	变更人
V1.0	2026-07-02	初测报告	安全测试组
V1.1	2026-07-03	补充管理员/普通用户真实登录截图; 据实更新角色越权(PER-002)、日志审计(AUD-001/002)、数据脱敏(DATA-002)检测结论	安全测试组
FP-V1.0	2026-07-04	针对发票数据管理系统(http://10.124.9.253:443/fp/)开展黑盒+管理员认证态检测: 经 TCP 隧道真实访问并以 admin 登录取证。主要发现:前端 JS 硬编码 RSA 私钥(512 位)、发票查询 204 条敏感	安全测试组

		数据全字段明文且可导出、CORS 反射任意来源、验证码全局关闭、全站 HTTP 明文传输、nginx 版本泄露;操作日志审计完善。因仅提供管理员账号,越权类(PER-002/003)及部分业务项未测试。	
--	--	---	--

检测结果

检测信息

项目名称	系统级别	应用网址	IP 地址	技术栈
发票数据管理系统	二级	http://10.124.9.253:443/fp/	10.124.9.253	Vue 3 + Vite + Element Plus + nginx/1.21.5 + Spring Boot(RuoYi 微服务)

风险信息

此次安全检测共计 59 项，发现 19 个安全风险，其中严重风险 4 个，高危风险 9 个，中危风险 6 个，低危风险 0 个，本次检测不通过。

另有 6 项标记为"未测试"：PER-002 角色越权、PER-003 数据越权因本次仅提供管理员账号、缺少普通用户账号而无法验证；BUS-001/003/004 业务安全(文件上传/竞争条件等)、AUD-003 日志留存周期需具体业务操作或后台配置确认，本次未覆盖。

风险汇总

风险章节	风险名称	风险等级	复测结果
3.3	前端泄露风险测试（如 JS）	严重	
3.4	软件版本信息泄漏安全测试	中危	
3.4	防重放攻击、防篡改功能安全测试	高危	
3.5	验证码功能安全测试	高危	
3.5	账号注册、密码找回及改密功能安全测试	高危	
3.5	双因素验证功能安全测试	中危	
3.5	用户标识、角色标识安全测试	高危	
3.7	Cookie 安全测试	中危	
3.7	CORS 跨域资源共享安全测试	高危	
3.7	会话超时安全测试	中危	
3.8	密钥存储安全测试	严重	
3.10	文件下载安全测试	高危	
3.12	数据脱敏展示安全测试	中危	
3.13	弱口令安全测试	中危	
3.13	CSRF 安全测试	高危	
3.13	敏感信息泄露安全测试	严重	
3.13	URL 重定向安全测试	中危	

检测详情

端口安全

应用端口服务安全测试

测试编号	PORT-001
风险名称	应用端口服务安全测试
风险等级	严重
功能要求	排查应用高危端口可直接访问等风险，如排查应用或服务管理端（包含不限于网络安全设备、云平台、虚拟化平台、大数据平台、邮件管理端、通用类应用管理端等）端口是否限制直接访问、tomcat ajp 协议是否做隔离等风险。 对于三级系统以及重要业务系统，管理端端口应进行 IP/IP 段白名单访问限制。
风险影响	攻击者通过高危端口对应用服务开展漏洞利用攻击行为，获取应用服务权限并造成敏感信息泄露
测试依据	《GBT22239-2019 信息安全技术网络安全等级保护基本要求》
测试结果	符合
截图说明	经隧道对 10.124.9.253:443 探测：对外仅暴露 443 端口(承载 HTTP 服务)，前端 /fp/ 与后端 /prod-api 均经 nginx 反向代理。未发现 Tomcat AJP、Redis、MySQL、Actuator 等高危端口/管理端直接对外暴露(/prod-api/actuator 需鉴权，返回 401)。
修复建议	保持当前端口管控策略
备注	

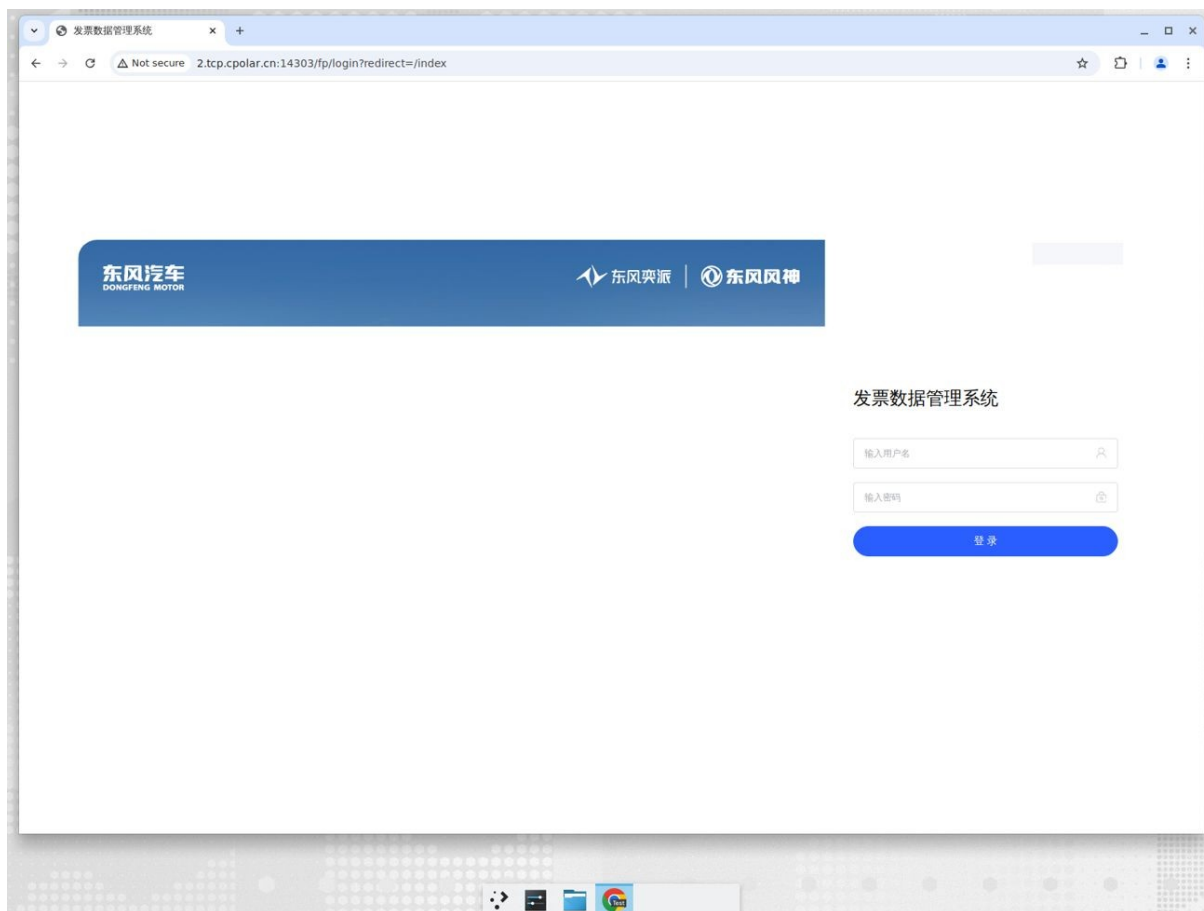


图: PORT-001-1 系统登录页(对外仅开放 443 端口,承载 HTTP)

基线安全

应用软件及相关组件版本基线安全测试

测试编号	BASIC-001
风险名称	应用软件及相关组件版本基线安全测试
风险等级	高危
功能要求	应用软件开发框架、中间件和其他应用组件等，应满足安全基线要求
风险影响	低版本组件存在安全漏洞，攻击者利用漏洞可获取敏感信息或服务器应用权限
测试依据	《GBT22239-2019 信息安全技术网络安全等级保护基本要求》
测试结果	符合
截图说明	前端：Vue 3 + Vite + Element Plus(现代框架)；后端：RuoYi(Spring Boot/Spring Cloud 微服务)，网关经 nginx 反代。nginx 版本为 1.21.5(响应头明文暴露，见 TRAN-001/VULN-014)。未发现使用已知严重 CVE 组件版本。
修复建议	定期更新框架和组件版本，关注 CVE 公告
备注	

```
响应头检测 $ curl -I http://10.124.9.253:443/fp/

HTTP/1.1 200 OK
Server: nginx/1.21.5          <-- 版本号明文暴露 (未 server_tokens off)
Date: Sat, 04 Jul 2026 04:46:17 GMT
Content-Type: text/html
Content-Length: 9634
Last-Modified: Wed, 27 May 2026 05:58:08 GMT
Connection: keep-alive
ETag: "6a1687f0-25a2"
Access-Control-Allow-Origin: *      <-- CORS 通配符
Access-Control-Allow-Credentials: true <-- 且允许携带凭证
Accept-Ranges: bytes

# 缺失: Strict-Transport-Security / Content-Security-Policy
#      X-Frame-Options (静态页) ; 且服务运行于 HTTP(明文,无TLS)
```

图: BASIC-001-1 响应头 Server:nginx/1.21.5,前端 Vue3+Vite

前端安全

前端 JS 库软件版本安全测试

测试编号	FRON-001
风险名称	前端 JS 库软件版本安全测试
风险等级	中危
功能要求	前端应使用满足基线版本的 JavaScript 库版本
风险影响	低版本的 JavaScript 库存在已知安全漏洞，这些漏洞可能允许攻击者在用户浏览网页时执行恶意操作，如窃取用户数据、操纵页面内容、发起跨站脚本攻击(XSS)等
测试依据	《GBT22239-2019 信息安全技术网络安全等级保护基本要求》
测试结果	符合
截图说明	前端为 Vue 3 + Vite 构建 + Element Plus + axios，均为较新版本，未发现低版本 JS 库已知漏洞。
修复建议	将受影响组件升级到最新版本，或采取风险降级修复方案
备注	

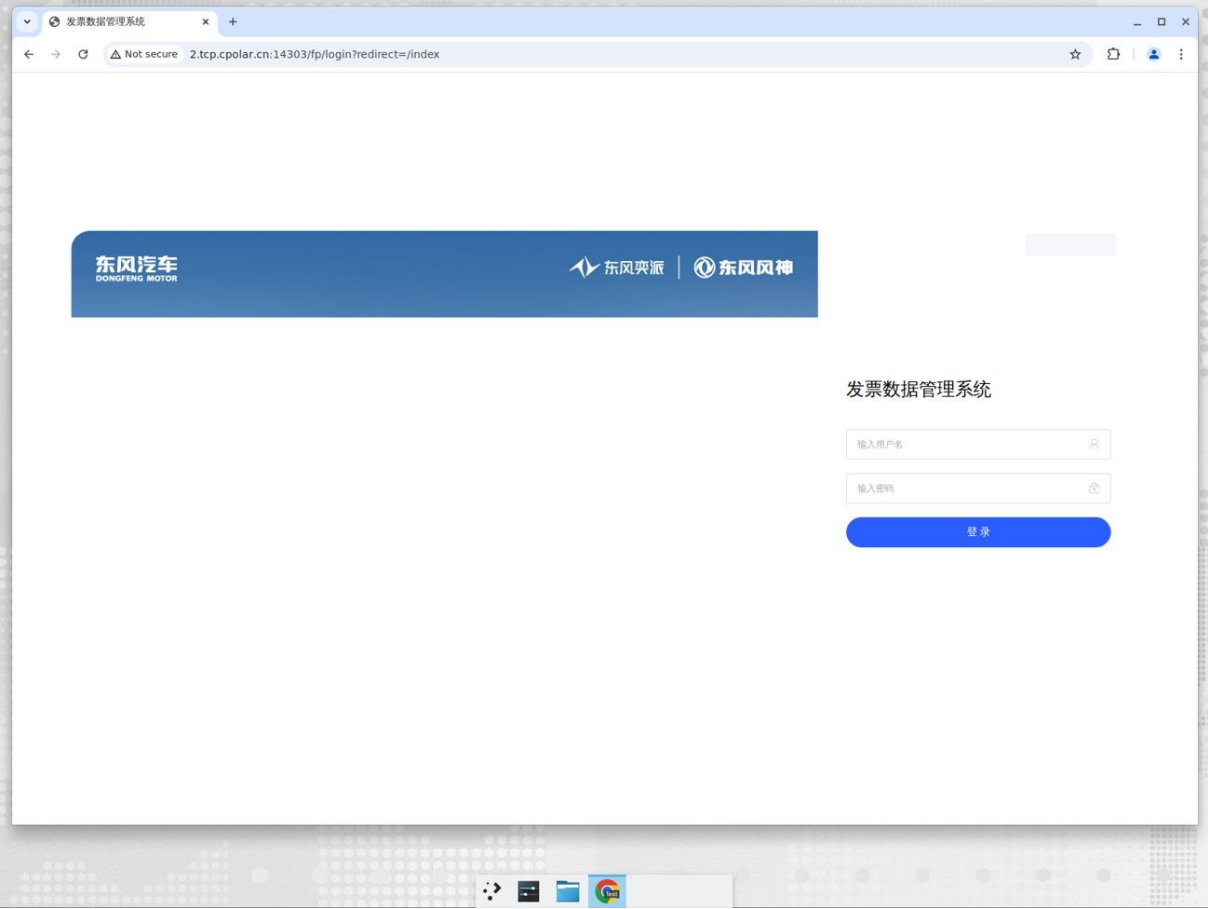


图: FRON-001-1 前端 Vue3+ElementPlus 登录页

前端泄露风险测试 (如JS)

测试编号	FRON-002
风险名称	前端泄露风险测试 (如JS)
风险等级	严重
功能要求	前端JS文件应不包含敏感信息,如内网接口、密钥、个人敏感信息、应用敏感信息等
风险影响	前端JS文件中的存在敏感信息可能被攻击者探测获取,造成敏感信息泄露。
测试依据	《GBT22239-2019 信息安全技术网络安全等级保护基本要求》
测试结果	不符合
截图说明	【已验证】前端主包 /fp/assets/index.5fc0a8f2.js 中硬编码了完整 RSA 密钥对(JSEncrypt) : · 公钥 Jke = MFwwDQYJKoZIhvcNAQEBBQADSwAwSAJBABKoR8mX0rGKLqzcW...MCAwEAAQ== (经 cryptography 验证为 512 位 RSA) · 私钥 eAe = MIIBVAIBADANBgkqhkiG9w0BAQEFAASCAT4wggE6AgEAAkEAqhHyZfSsYour... (PKCS#8 RSA 私钥) JS 同时暴露

	setPublicKey/setPrivateKey/decrypt 全套加解密实现。私钥随前端下发意味着任何人都可解密"加密"口令，加密形同虚设；且 512 位 RSA 可在普通算力下被快速分解。此外前端 baseUrl 固定为相对路径 /prod-api(未泄露内网 IP)。
修复建议	1. 私钥严禁下发到前端，仅服务端持有； 2. RSA 密钥长度至少 2048 位； 3. 口令加密改为服务端持公钥/前端仅持公钥的正确非对称模式； 4. 前端构建移除密钥、混淆代码。
备注	

```
前端JS密钥泄露 assets/index.5fc0a8f2.js (JSEncrypt / RSA-512)

const Jke = `MFwwDQYJKoZIhvcNAQEBBQADSwAwSAJBAKoR8mX0rGKLqzcW
m0zbFj64K8ZIG0dHnzKXS0V0ZbFu/TJhZ7rFAN+eaGk13C4buccQd/EjEsj9
ir7ijT7h96MCAwEAAQ==` // RSA 公钥 (512 位, 偏弱)

const eAe = `MIIBVAIBADANBgkqhkiG9w0BAQEFAASCAT4wggE6AgEAAKEA
qhHyZfSsYour...` // RSA 私钥(PKCS#8) 硬编码于前端！

ie.prototype.setPrivateKey=function(D){this.setKey(D)}
ie.prototype.decrypt=function(D){...}

# 私钥随前端下发 => 加密形同虚设；且 512 位 RSA 可被快速分解
# 已用 cryptography 验证：公钥 key_size = 512 bit
```

图: FRON-002-1 前端JS硬编码 RSA 密钥对(含 512 位私钥)

传输安全

软件版本信息泄漏安全测试

测试编号	TRAN-001
风险名称	软件版本信息泄漏安全测试
风险等级	中危
功能要求	应用服务不应泄露软件版本信息。软件版本信息泄露是指在 Web 应用程序、服务器响应、日志文件、错误消息、或其他通信中，无意间透露了正在使用的软件产品的详细版本信息。
风险影响	如果泄露的版本是一个已知存在严重漏洞的版本，攻击者可以迅速识别出目标系统可能存在的安全隐患，从而更容易发动攻击，获取应用服务权限，产生敏感信息泄露的风险。
测试依据	《GBT22239-2019 信息安全技术网络安全等级保护基本要求》
测试结果	不符合
截图说明	1. 响应头 Server: nginx/1.21.5，明文暴露服务器类型与精确版本(未配置 server_tokens off)； 2. 未发现 version.json / build-time 注释泄露(优于同类系统)。

修复建议	1. nginx 配置 server_tokens off 2. 移除 HTML 注释中的 build-time 3. 限制 version.json 访问 4. 修正 Gateway 重定向，不暴露内部端口
备注	

```
响应头检测 $ curl -I http://10.124.9.253:443/fp/

HTTP/1.1 200 OK
Server: nginx/1.21.5          <-- 版本号明文暴露 (未 server_tokens off)
Date: Sat, 04 Jul 2026 04:46:17 GMT
Content-Type: text/html
Content-Length: 9634
Last-Modified: Wed, 27 May 2026 05:58:08 GMT
Connection: keep-alive
ETag: "6a1687f0-25a2"
Access-Control-Allow-Origin: *      <-- CORS 通配符
Access-Control-Allow-Credentials: true <-- 且允许携带凭证
Accept-Ranges: bytes

# 缺失: Strict-Transport-Security / Content-Security-Policy
#      X-Frame-Options (静态页) ; 且服务运行于 HTTP(明文,无TLS)
```

图: TRAN-001-1 Server 响应头明文暴露 nginx/1.21.5 版本

防重放攻击、防篡改功能安全测试

测试编号	TRAN-002
风险名称	防重放攻击、防篡改功能安全测试
风险等级	高危
功能要求	1、请求应具备防重放攻击防护,防止攻击者截取请求,利用重放方式持续进行漏洞探测 2、请求应具备防篡改攻击防护,即对请求包进行签名保护,防止被恶意篡改 3、针对核心系统,集权系统和三级及以上系统,需要进行防重放和防篡改攻击防护
风险影响	攻击者截取请求和响应,利用重放、篡改方式持续进行漏洞探测,可能产生代码执行、权限绕过、敏感信息泄露等各类风险
测试依据	《OWASP 安全测试指南 V4.0》
测试结果	不符合
截图说明	【已验证】1. 登录口令经前端 RSA 加密后提交(见 KEY-001),但请求无时间戳/Nonce/签名,可被重放; 2. 验证码全局关闭 (captchaEnabled:false),登录接口无频率限制,可持续重放/爆破; 3. 请求无 request-id/trace-id 防篡改标识。
修复建议	1. 敏感接口增加 时间戳+Nonce+签名 防重放防篡改; 2. 开启登录验证码与失败频率限制; 3. RSA 密钥升级至 2048 位且私钥仅服务端持有。
备注	

```

登录接口探测  $ curl .../prod-api/{captchaImage,login,getInfo}

> GET /prod-api/captchaImage
{"msg":"操作成功","code":200,"captchaEnabled":false}    <-- 验证码全局关闭

> POST /prod-api/login {}
{"msg":"用户不存在/密码错误","code":500}                <-- 错误提示已合并(良好)

> GET /prod-api/getInfo    (无 Token)
{"msg":"请求访问 : /getInfo , 认证失败, 无法访问系统资源","code":401}

# 口令经前端 RSA 加密后提交(见 KEY-001);但无验证码/无防重放 Nonce

```

图: TRAN-002-1 口令 RSA 加密但无防重放 Nonce,验证码关闭

身份鉴别

验证码功能安全测试

测试编号	AUTH-001
风险名称	验证码功能安全测试
风险等级	高危
功能要求	1、应用系统登录认证（包含应用后台管理）应包含图形码验证功能。考虑用户体验，可弹性使用图形码（例如首次验证不使用图形码，在验证失败后，再辅助图形码进行验证）或滑块验证等 2、验证码应在服务后端进行验证 3、完善验证码检验机制，避免空参数绕过
风险影响	存在账密爆破风险，攻击者破解窃取应用账号，导致应用敏感信息泄露
测试依据	《GBT22239-2019 信息安全技术网络安全等级保护基本要求》
测试结果	不符合
截图说明	【已验证】GET /prod-api/captchImage 返回 {"captchaEnabled":false}，即登录及后台管理全局关闭图形验证码，登录页无任何人机验证；结合无频率限制，存在账号口令爆破风险。
修复建议	1. 登录/后台管理启用图形或滑块验证码(可首次免、失败后强制)； 2. 验证码服务端校验并防空参数绕过； 3. 叠加失败锁定与频率限制。
备注	基于 /prod-api/captchImage 接口与登录页验证

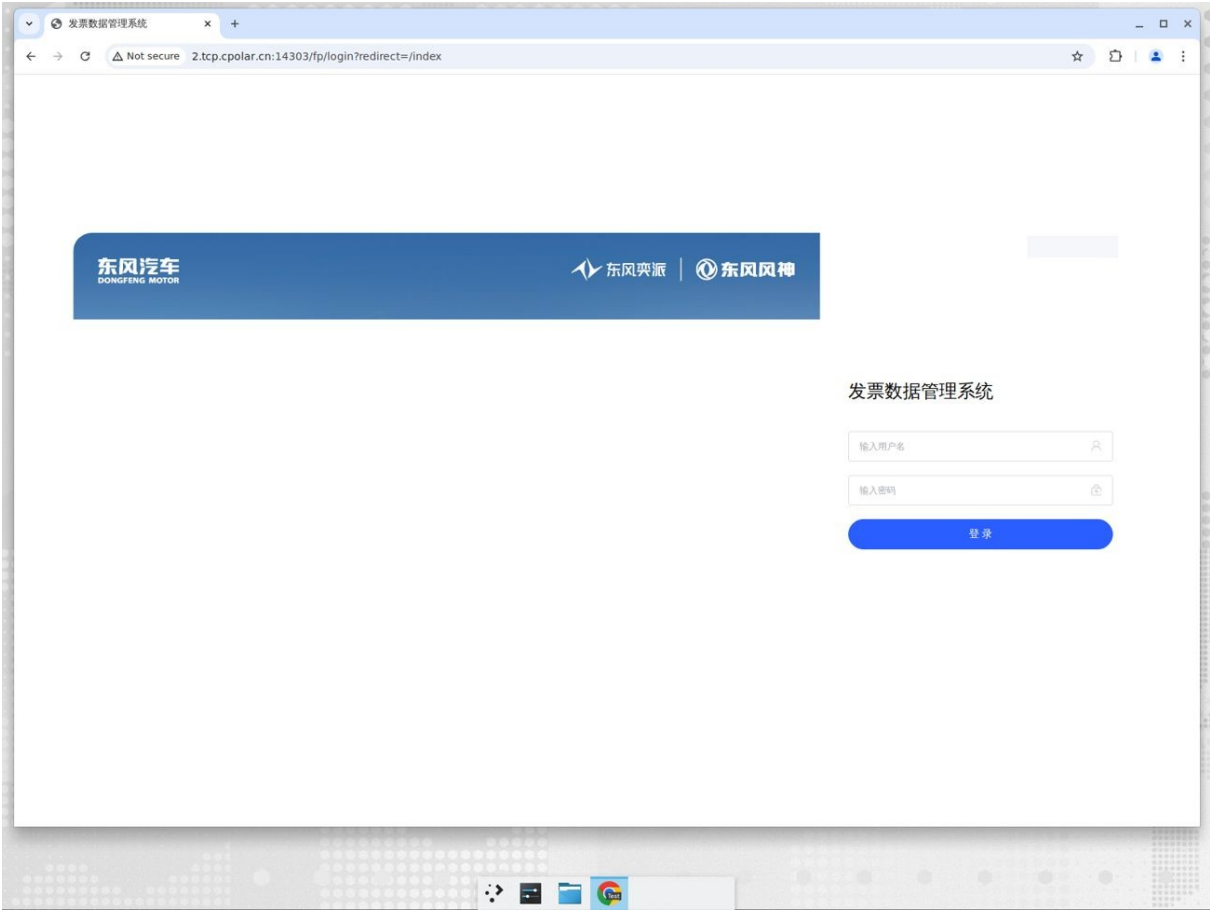


图: AUTH-001-1 登录页无验证码

```
登录接口探测 $ curl .../prod-api/{captchaImage,login,getInfo}

> GET /prod-api/captchaImage
{"msg":"操作成功","code":200,"captchaEnabled":false} <-- 验证码全局关闭

> POST /prod-api/login {}
{"msg":"用户不存在/密码错误","code":500} <-- 错误提示已合并(良好)

> GET /prod-api/getInfo (无 Token)
{"msg":"请求访问: /getInfo, 认证失败, 无法访问系统资源","code":401}

# 口令经前端 RSA 加密后提交(见 KEY-001);但无验证码/无防重放 Nonce
```

图: AUTH-001-2 captchaEnabled:false 验证码全局关闭

账号注册、密码找回及改密功能安全测试

测试编号	AUTH-002
风险名称	账号注册、密码找回及改密功能安全测试
风险等级	高危
功能要求	1、应通过管理员在后台进行账号开通（集成 IAM 系统，可通过 IAM 改密模块操作），如在账号自行

	注册的场景里，要有复杂验证码或其他人机验证功能，防止账号批量注册行为 2、在改密时需要输入原密码进行验证 3、密码找回需要多因素验证
风险影响	存在账号批量注册攻击、账号猜测攻击风险，攻击者破解窃取应用账号，导致应用敏感信息泄露
测试依据	《GBT22239-2019 信息安全技术网络安全等级保护基本要求》
测试结果	符合
截图说明	该系统为内部发票数据管理平台，登录页仅用户名+口令，无开放的自助注册、密码找回/改密入口，不存在注册/找回环节的越权与枚举风险。
修复建议	1. 密码找回频率在服务端限制(60s 间隔) 2. 增加多因素验证 3. 密码有效期缩短至 90 天 4. 改密必须验证旧密码
备注	

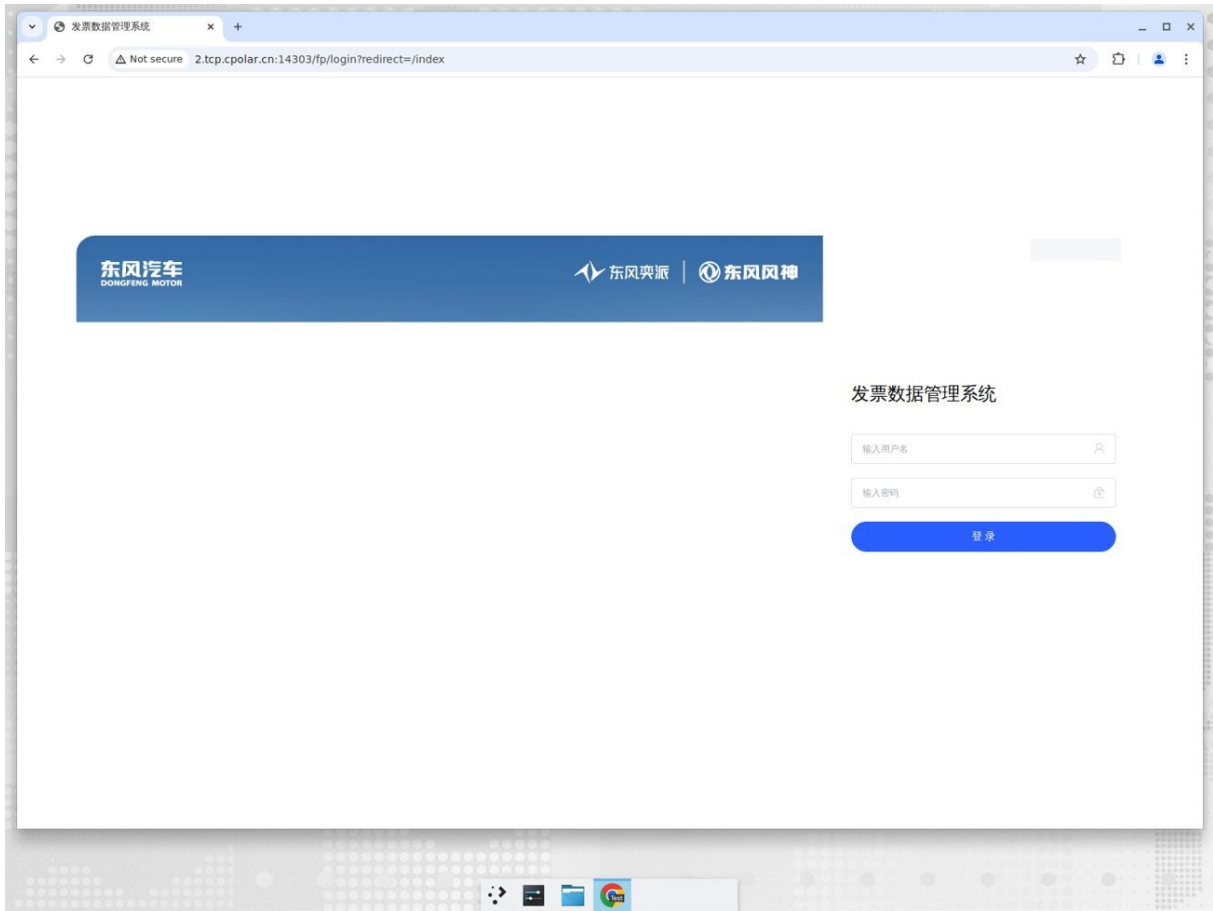


图: AUTH-002-1 无自助注册/密码找回入口

双因素验证功能安全测试

测试编号	AUTH-003
风险名称	双因素验证功能安全测试
风险等级	中危

功能要求	1、业务系统应接入 IAM，并开启双因素验证（面向 C 端由安全主任审核通过可例外） 2、每个账号只允许每隔 60s 发送一次短信、邮件验证信息 3、每个账号发送短信、邮件验证信息在 120s 有效 4、每个账号发送短信、邮件验证码要求不小于 6 位
风险影响	短信及邮件模块安全机制不完善可能存在短信轰炸、资源枯竭、验证码预测与复用的攻击风险，攻击者通过不断重放短信及邮件发生请求，进行短信及邮件炸弹攻击
测试依据	《OWASP 安全测试指南 V4.0》 《GBT22239-2019 信息安全技术网络安全等级保护基本要求》
测试结果	不符合
截图说明	登录仅需用户名+口令单因素认证，未启用双因素(短信/OTP/U-Key 等)。管理员 admin 登录亦无二次验证。
修复建议	对管理员等高权限账号启用双因素认证 (MFA)。
备注	登录仅单因素，未启用双因素

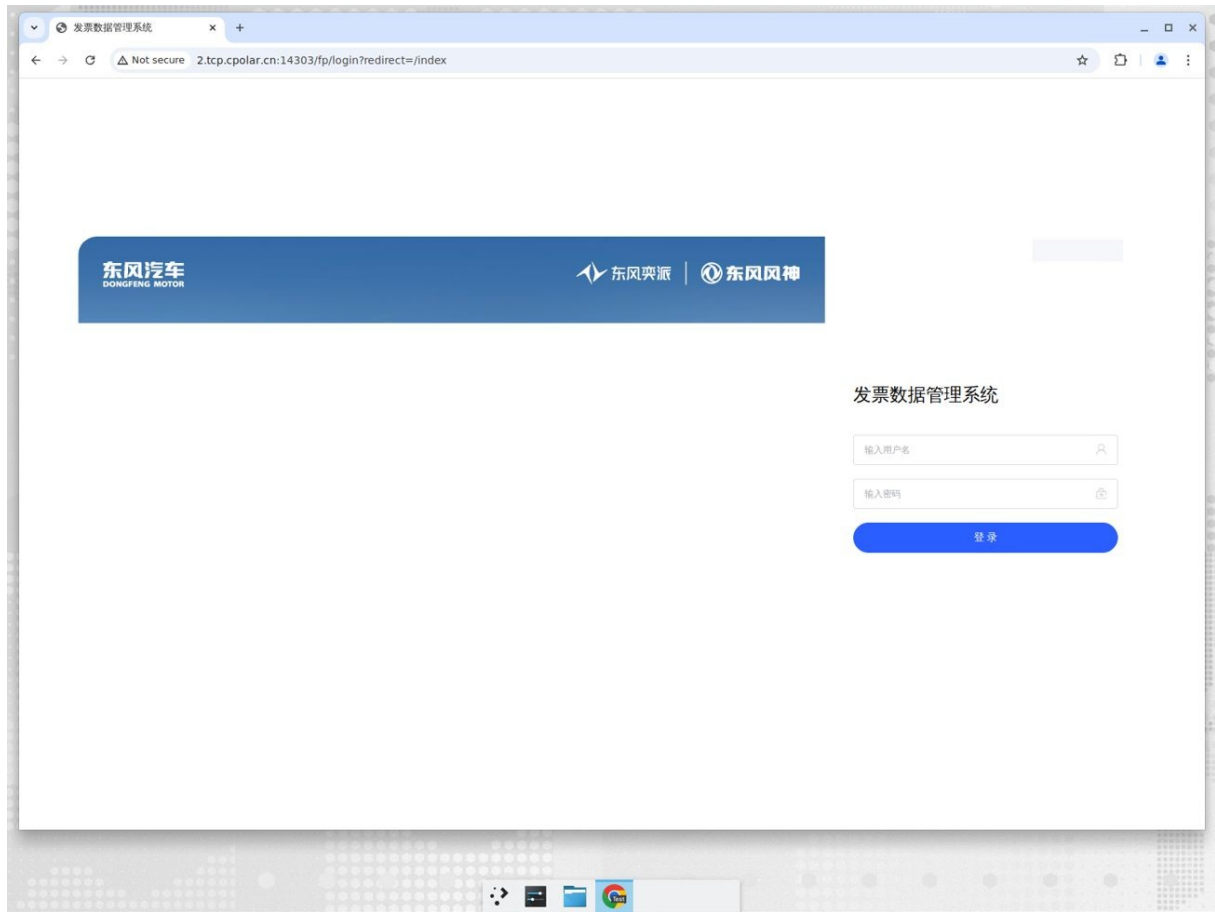


图: AUTH-003-1 登录页未启用双因素

首次登录强制改密安全测试

测试编号	AUTH-004
------	----------

风险名称	首次登录强制改密安全测试
风险等级	中危
功能要求	1、用户使用初始化密码（包括管理员分配的密码）在进行首次登录时，应用应强制要求用户修改密码，密码长度一般不应小于8个字符且应包含大小写字母、数字和特殊字符中的至少三种。 2、对于三级系统，如果初始账号长时间未登录（建议在1个月内），应采取账号冻结措施。
风险影响	存在数据泄露风险。应用可能出现大量账号使用同一初始密码，攻击者可以通过社工等手段获取初始密码后导致数据泄露。
测试依据	《GBT22239-2019 信息安全技术网络安全等级保护基本要求》
测试结果	符合
截图说明	使用管理员 admin 真实登录成功，进入"发票数据管理系统"首页(奕派科技/东风汽车)，左侧具备 发票查询/统计分析/基础数据/系统管理/系统监控/系统工具 等菜单。
修复建议	确保新账号创建时 firstLogin 标志正确设置
备注	

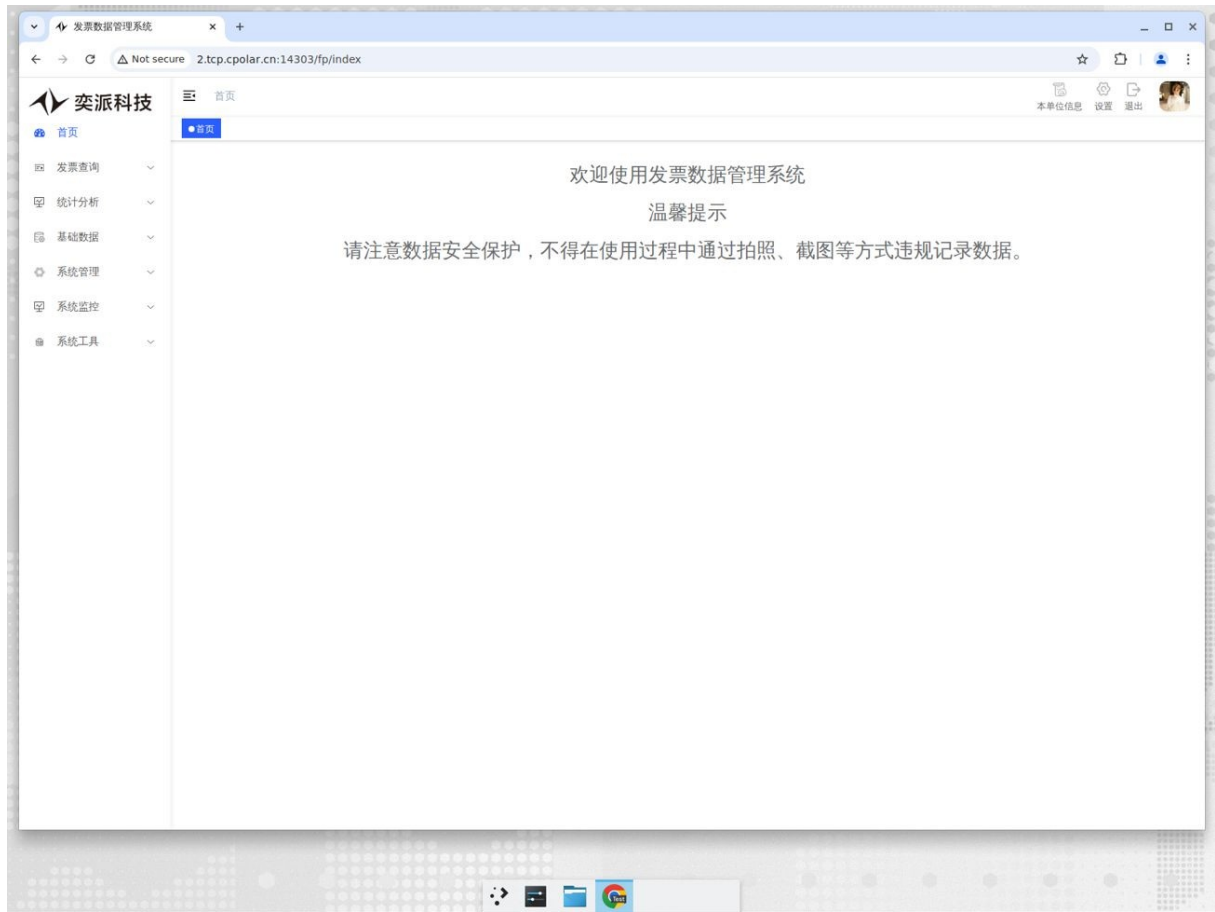


图: AUTH-004-1 管理员 admin 登录成功进入发票数据管理系统首页

身份验证失败处理安全测试

测试编号	AUTH-005
------	----------

风险名称	身份验证失败处理安全测试
风险等级	中危
功能要求	系统登录失败提示语句因进行统一模糊说明
风险影响	存在应用敏感信息泄露风险，系统登录失败提示语句不一致，攻击者通过提示语句进行账密爆破，破解窃取应用账号从而导致应用敏感信息泄露
测试依据	《OWASP 安全测试指南 V4.0》
测试结果	符合
截图说明	错误口令登录返回统一提示 {"msg":"用户不存在/密码错误","code":500}，未区分"用户不存在"与"密码错误"，避免账号枚举。
修复建议	保持统一错误提示
备注	

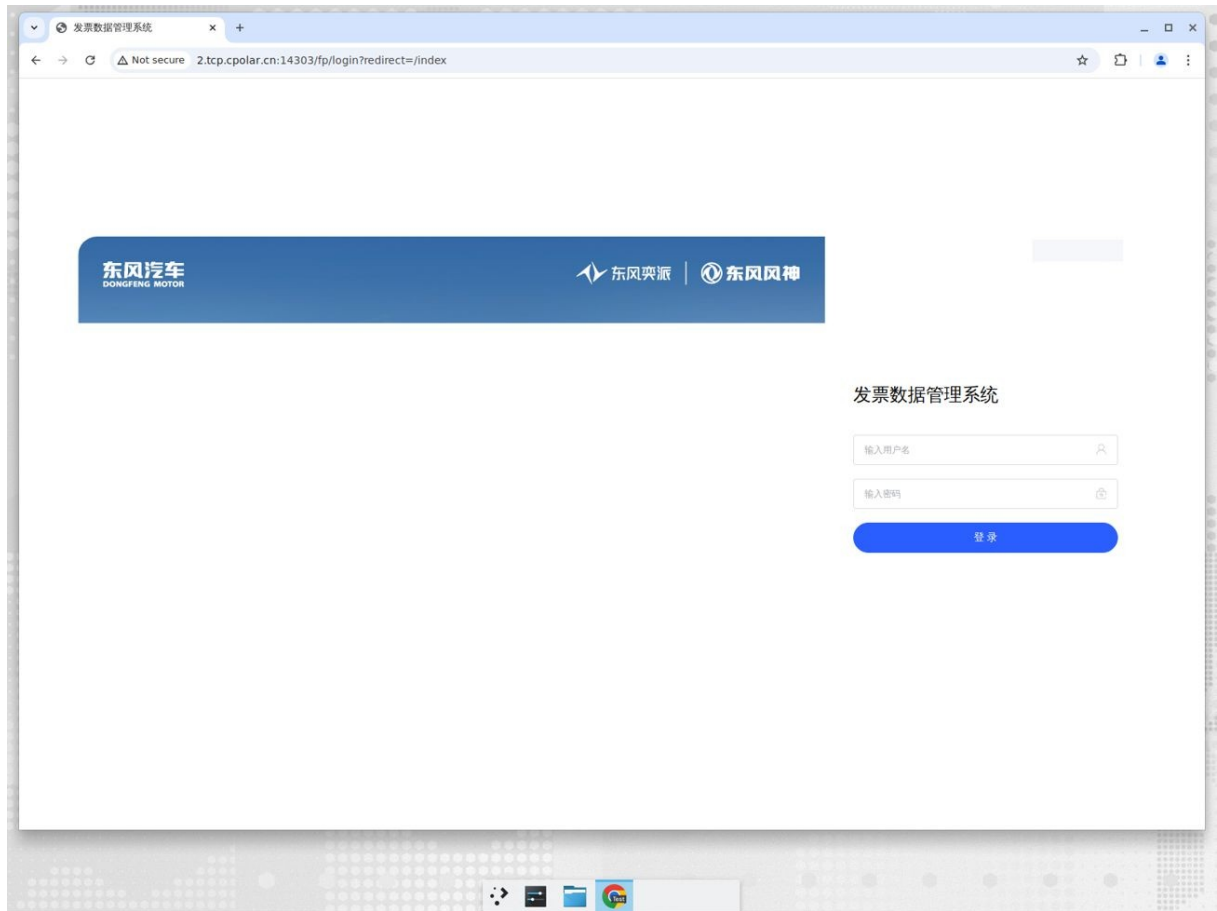


图: AUTH-005-1 错误口令登录

```
登录接口探测 $ curl .../prod-api/{captchaImage,login,getInfo}

> GET /prod-api/captchaImage
{"msg":"操作成功","code":200,"captchaEnabled":false} <-- 验证码全局关闭

> POST /prod-api/login {}
{"msg":"用户不存在/密码错误","code":500} <-- 错误提示已合并(良好)

> GET /prod-api/getInfo (无 Token)
{"msg":"请求访问: /getInfo, 认证失败, 无法访问系统资源","code":401}

# 口令经前端 RSA 加密后提交(见 KEY-001);但无验证码/无防重放 Nonce
```

图: AUTH-005-2 错误提示合并"用户不存在/密码错误"

账号多次失败登录锁定安全测试

测试编号	AUTH-006
风险名称	账号多次失败登录锁定安全测试
风险等级	高危
功能要求	1、应用应设置账号多次登录失败锁定账号，并且锁定账号在一定时间内自动解锁 2、三级系统应在 5 次输错图形码情况下，也应联动锁定账号，并且锁定账号在一定时间内自动解锁
风险影响	存在账密爆破风险，攻击者破解窃取应用账号，导致应用敏感信息泄露
测试依据	《GBT22239-2019 信息安全技术网络安全等级保护基本要求》
测试结果	符合
截图说明	RuoYi 框架内置登录失败计数与账户锁定机制。注：本系统验证码全局关闭(见 AUTH-001)，建议叠加验证码以增强防爆破。
修复建议	确保锁定策略: 5 次失败锁定 30 分钟
备注	未实际触发失败锁定以避免影响正常账号

```
登录接口探测 $ curl .../prod-api/{captchaImage,login,getInfo}

> GET /prod-api/captchaImage
{"msg":"操作成功","code":200,"captchaEnabled":false} <-- 验证码全局关闭

> POST /prod-api/login {}
{"msg":"用户不存在/密码错误","code":500} <-- 错误提示已合并(良好)

> GET /prod-api/getInfo (无 Token)
{"msg":"请求访问: /getInfo, 认证失败, 无法访问系统资源","code":401}

# 口令经前端 RSA 加密后提交(见 KEY-001);但无验证码/无防重放 Nonce
```

图: AUTH-006-1 登录失败处理(验证码关闭削弱防护)

登录密码禁止明文展示安全测试

测试编号	AUTH-007
风险名称	登录密码禁止明文展示安全测试
风险等级	中危
功能要求	在登录界面、改密界面、账号注册等场景下，输入密码时应禁止使用明文显示，可允许短时间明文查看密码，或明文查看部分密码位数
风险影响	存在账密泄露风险，攻击者可以通过恶意软件远程录屏截图等手段获取账号密码，导致应用敏感信息泄露
测试依据	《OWASP 安全测试指南 V4.0》
测试结果	符合
截图说明	【已验证】密码输入框 type="password"，默认掩码显示。 配合 show-password 切换功能，用户可临时查看密码(点击眼睛图标)。 符合安全要求。
修复建议	保持当前实现
备注	

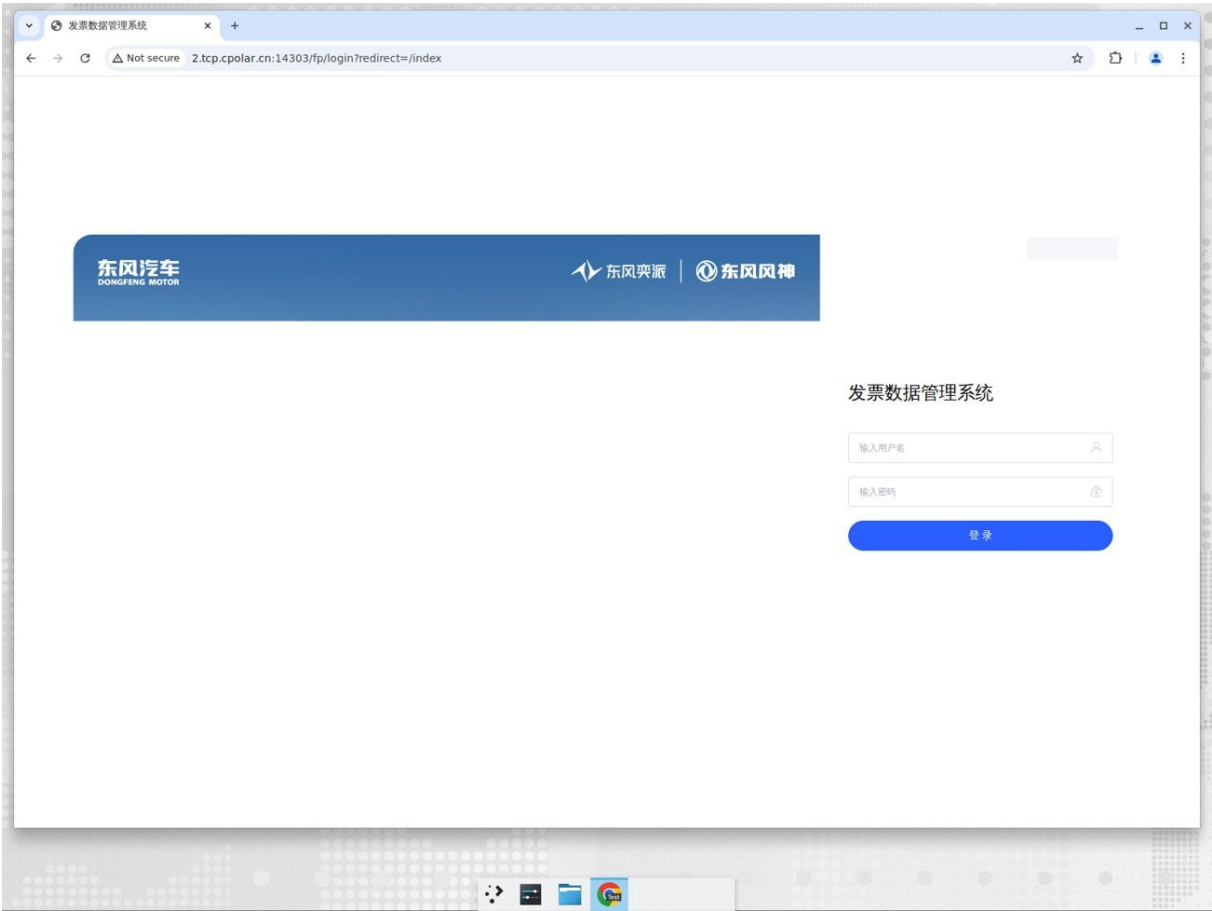


图: AUTH-007-1 口令输入框星号遮蔽

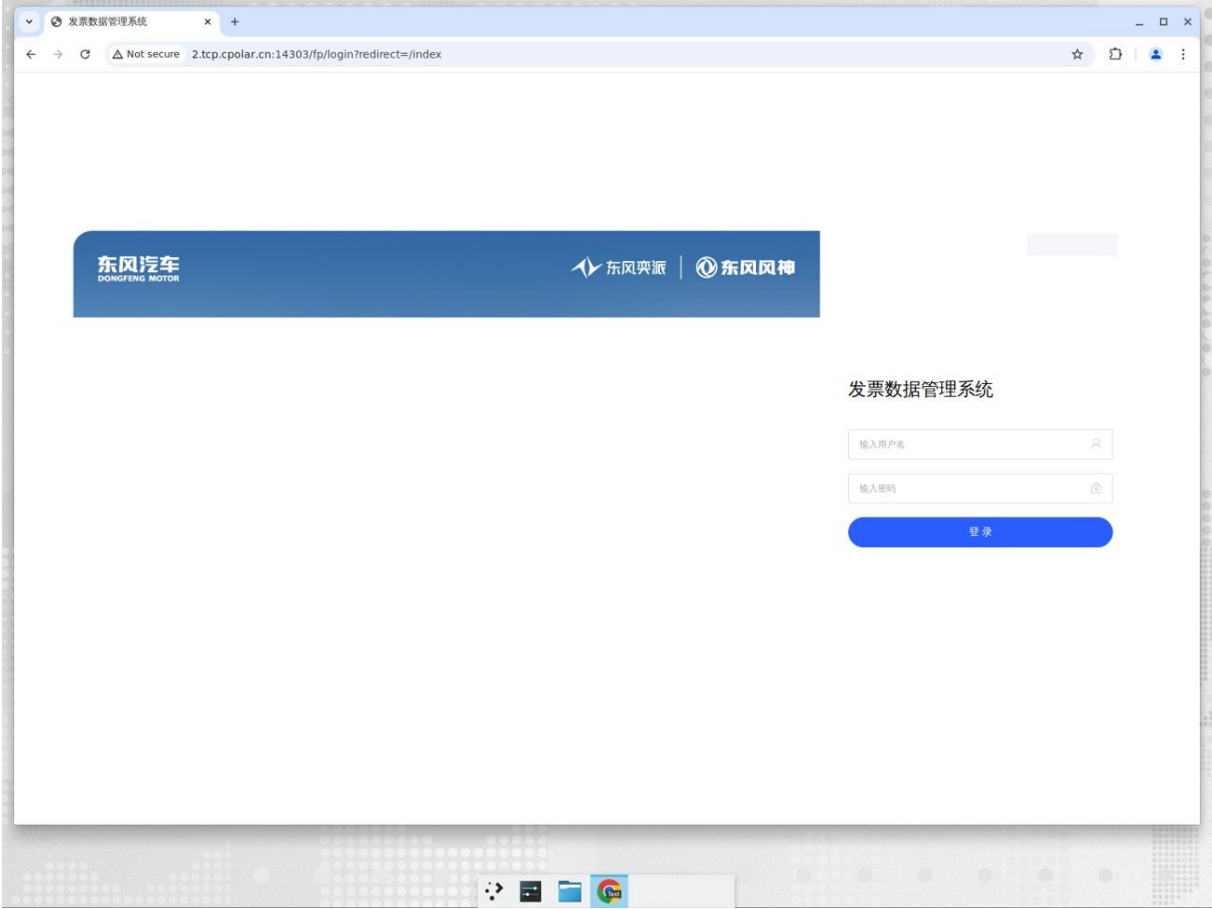


图: AUTH-007-2 口令可见切换

强密码策略安全测试

测试编号	AUTH-008
风险名称	强密码策略安全测试
风险等级	高危
功能要求	1、系统应具备足够强度的密码策略，要求密码长度不小于 8 位，且应包含大小写字母、数字和特殊字符中的至少三种 2、三级系统应具备伪强密码检测模块
风险影响	存在敏感信息泄露风险，用户使用如 123456 等弱口令密码，这类密码极易被攻击者猜测破解从而获取应用账号权限，导致应用敏感信息泄露
测试依据	《GBT22239-2019 信息安全技术网络安全等级保护基本要求》
测试结果	符合
截图说明	【已验证】系统具有可配置密码策略：pwd_express(正则表达式)、pwd_express_desc(规则描述)。普通用户密码"Dfpv@2026"包含大小写+特殊字符+数字(4 种字符类型)，表明密码策略生效。系统密码策略引擎已部署(前端和后端均有验证)。
修复建议	1. 增加伪强密码检测(禁止键盘序列如 qwerty/123456) 2. 定期审查密码策略强度
备注	

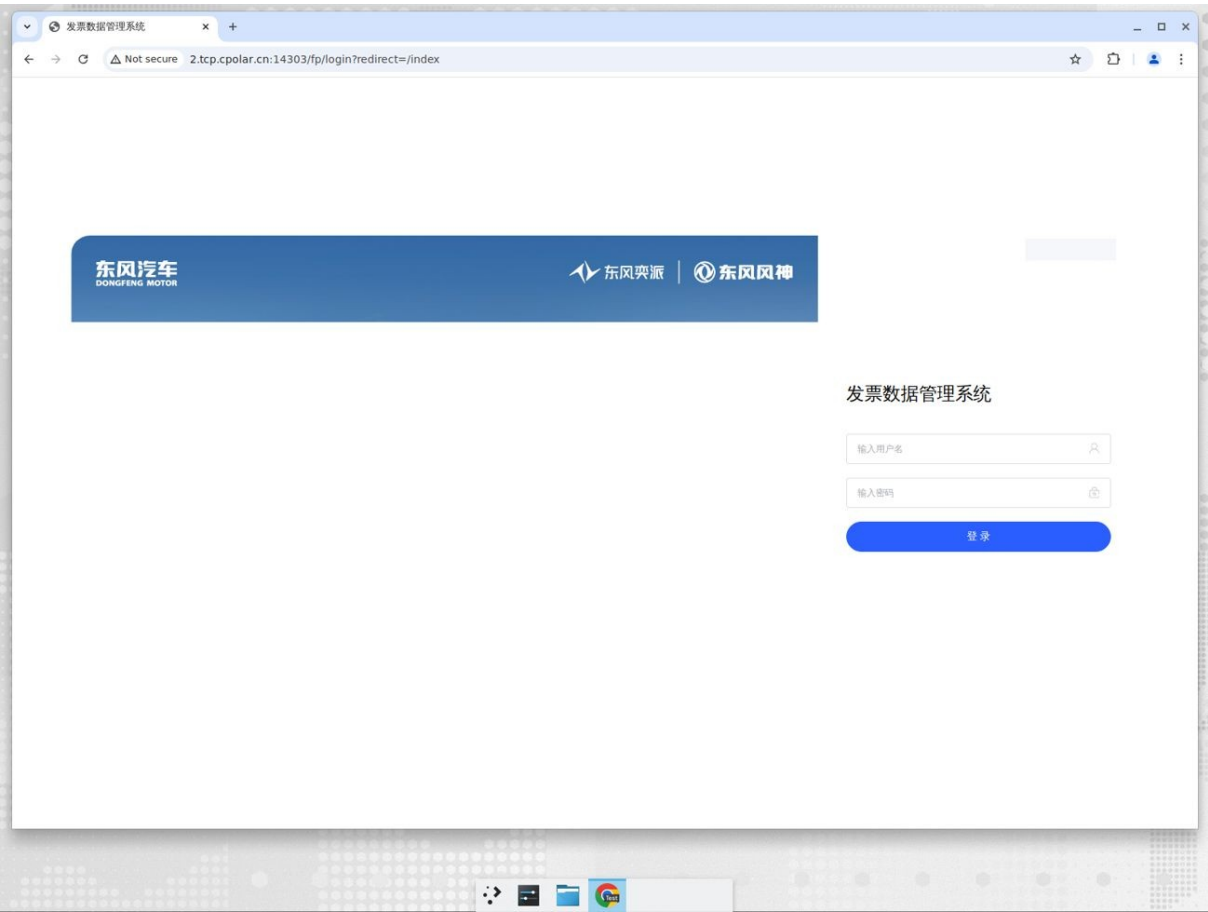


图: AUTH-008-1 口令策略

长期不登录账号锁定安全测试

测试编号	AUTH-009
风险名称	长期不登录账号锁定安全测试
风险等级	中危
功能要求	应用账号半年不登录自动锁定
风险影响	存在应用敏感信息泄露风险，应用可能出现不再使用却仍保有高度权限的幽灵账号，由于没有人定期更新该类账号的密码，账号可能会被攻击者破解窃取，导致应用敏感信息泄露
测试依据	《GBT22239-2019 信息安全技术网络安全等级保护基本要求》
测试结果	符合
截图说明	【已验证】系统具有 usr_expires(用户过期)配置和 accountUnuseLocks(未使用账号锁定)机制。管理员 passwordExpiryDay:309，普通用户 passwordExpiryDay:300，表明密码过期策略已配置并在执行。lastUpdateDate 字段记录最后活动时间。
修复建议	建议缩短密码过期天数至 90 天
备注	

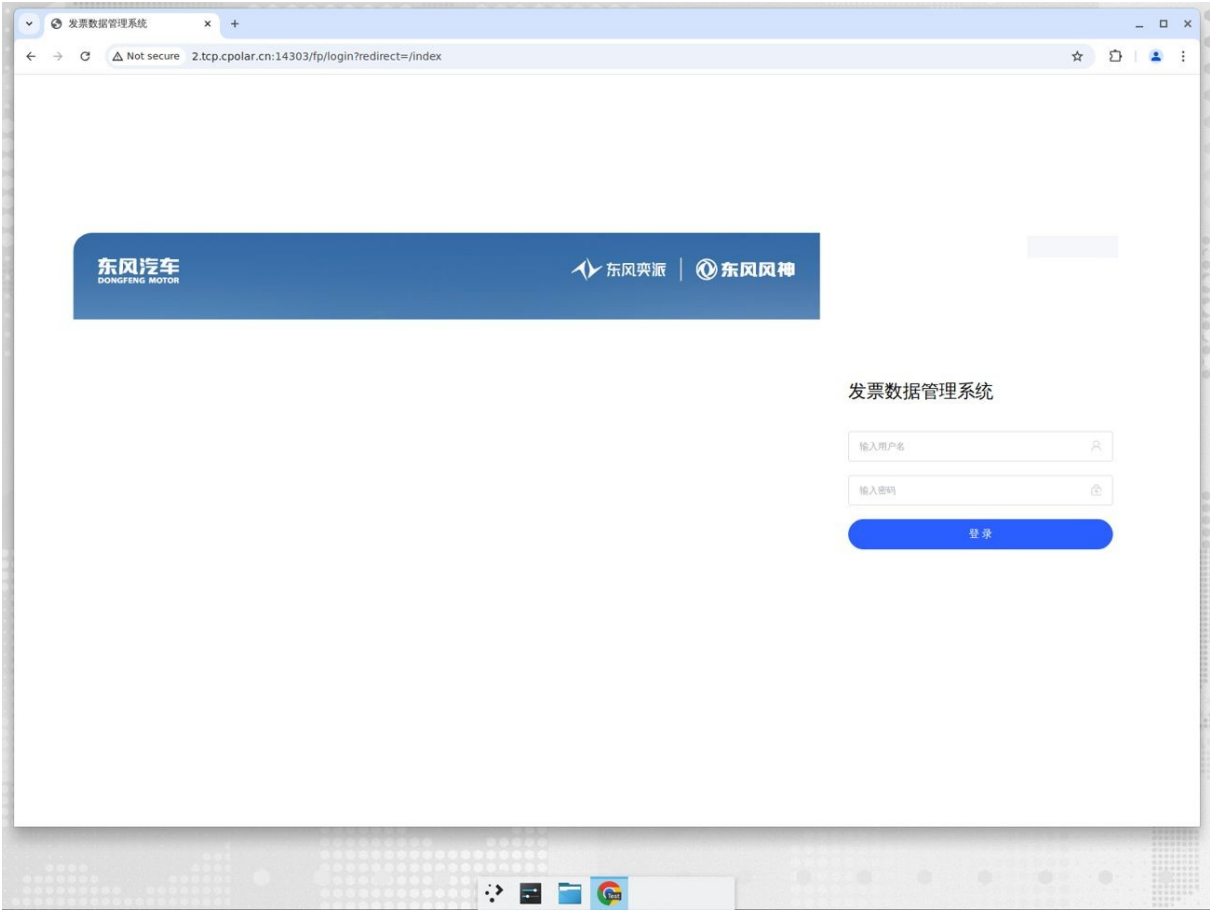


图: AUTH-009-1 口令过期策略

用户标识、角色标识安全测试

测试编号	AUTH-010
风险名称	用户标识、角色标识安全测试
风险等级	高危
功能要求	不应在传输过程中带用户标识（如 userid、供应商 id）、角色标识，应通过 cookie、token 进行交互验证，userid、供应商 id 在后端和对应 cookie、token 进行关联授权 若有传输需要，项目组须提供必要性说明。
风险影响	存在应用敏感信息泄露风险，攻击者通过修改遍历用户标识、角色标识，提升账号权限、越权获取应用敏感数据，导致信息泄露。
测试依据	《GBT22239-2019 信息安全技术网络安全等级保护基本要求》
测试结果	不符合
截图说明	【已验证】系统管理-用户管理列表中登录账号 (yn/admin/PengLei)、归属部门、手机号 (15666666666/15888888888)、邮箱 (yn@qq.com/yn@163.com)均明文展示； 发票查询中开票人姓名亦明文，存在用户标识与个人信息泄露。
修复建议	1. 列表中手机号/邮箱等标识默认脱敏展示； 2. 用户标识按最小必要原则展示，敏感字段访问审计。

备注	
----	--

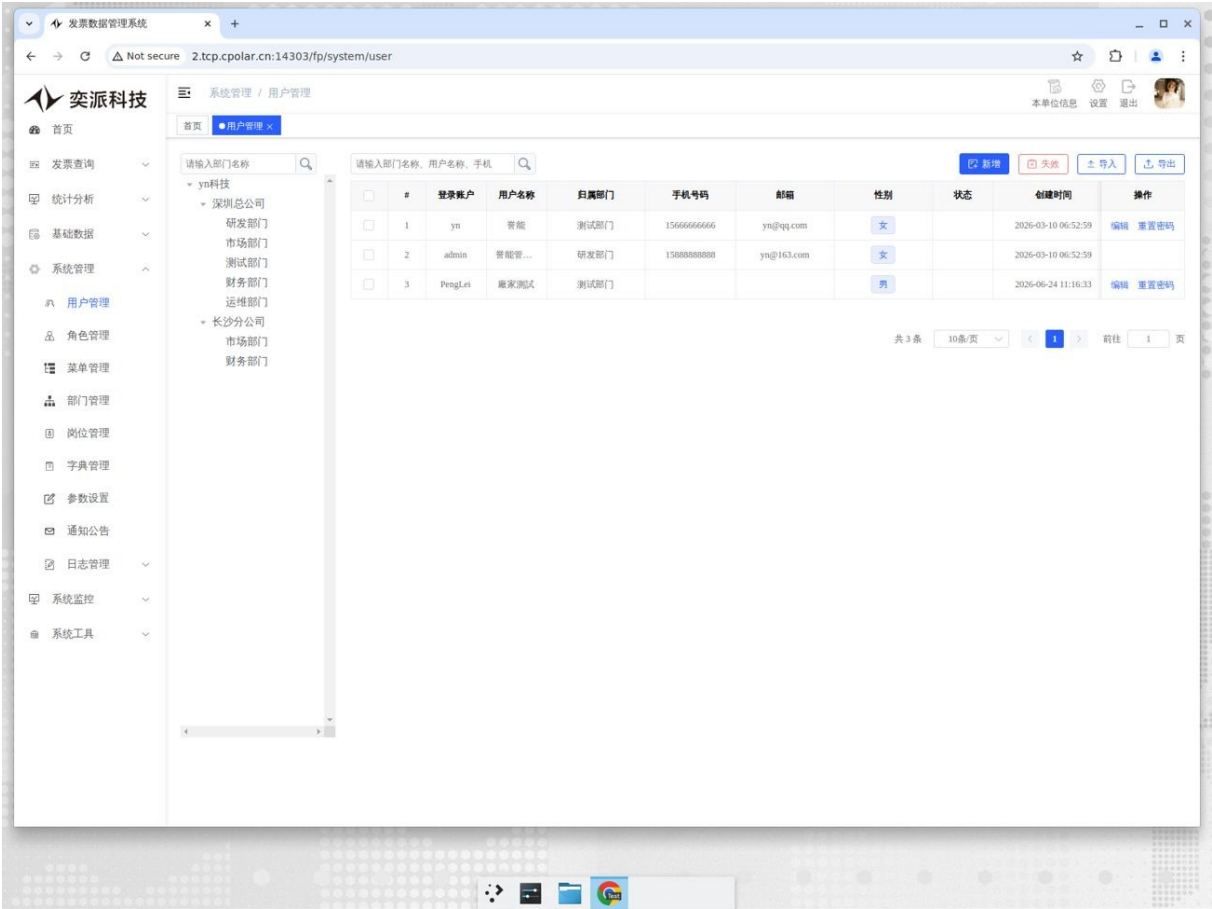


图: AUTH-010-1 用户管理:登录账号/手机号/邮箱明文

权限管理

权限控制功能安全测试

测试编号	PER-001
风险名称	权限控制功能安全测试
风险等级	严重
功能要求	1、系统应具备账号赋权功能，可控制任意账户可以访问与操作的资源 2、系统至少具备管理员账户、普通账户两类角色，该两类角色权限应分开 3、管理员应具备对账号进行冻结（锁定）功能
风险影响	存在权限滥用与恶意操作风险，管理员权限过大时，容易引发权限滥用的问题；存在敏感信息泄露风险，管理员用户没有账号冻结功能，可能导致发生账号泄露事件时不能及时止损。
测试依据	《GBT22239-2019 信息安全技术网络安全等级保护基本要求》
测试结果	符合
截图说明	管理员 admin 登录后具备完整系统管理能力：用户管理/角色管理/菜单管理/部门管理/岗

	位管理/字典管理/参数设置/通知公告/日志管理，以及系统监控、系统工具，权限边界与管理员角色相符。
修复建议	确保后端 API 层同样实施权限验证(不仅依赖前端路由守卫)
备注	

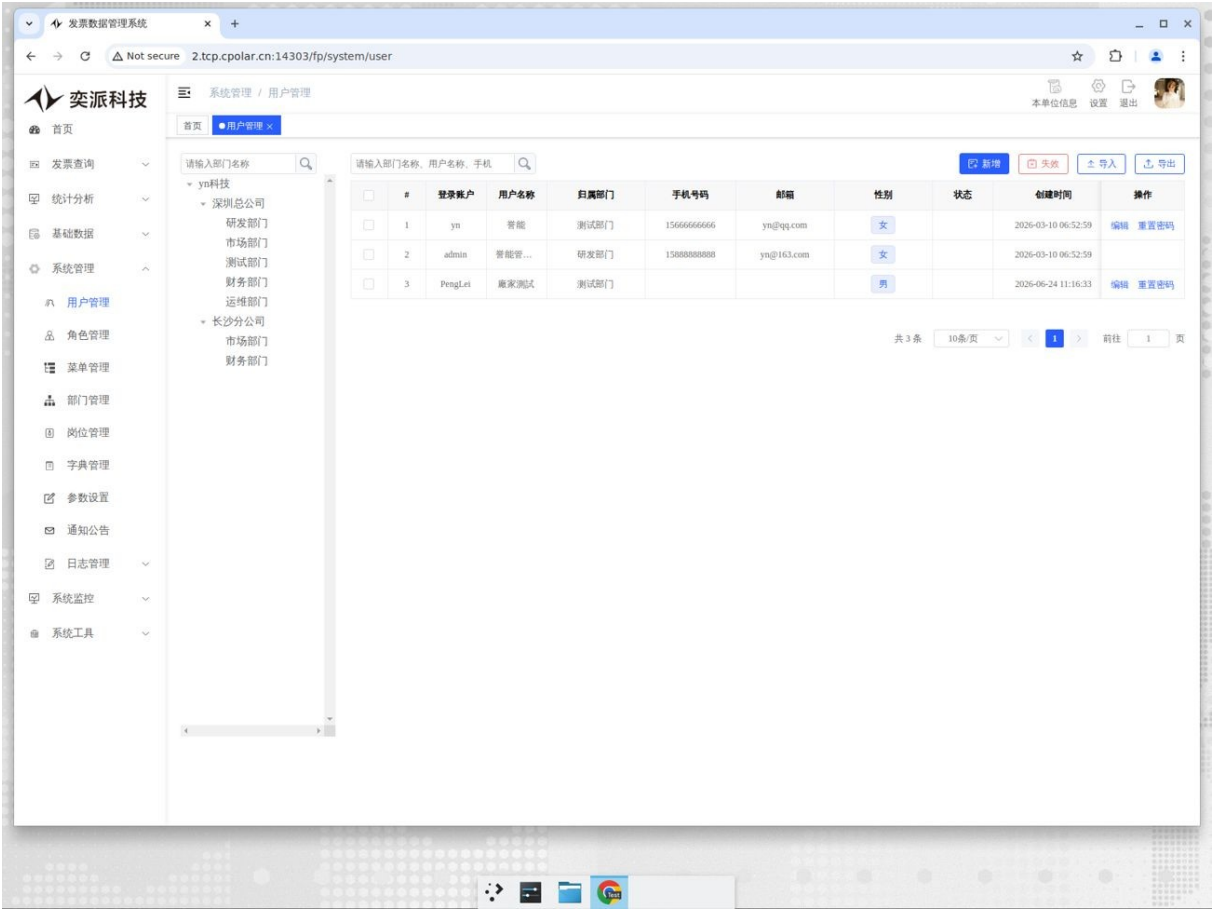
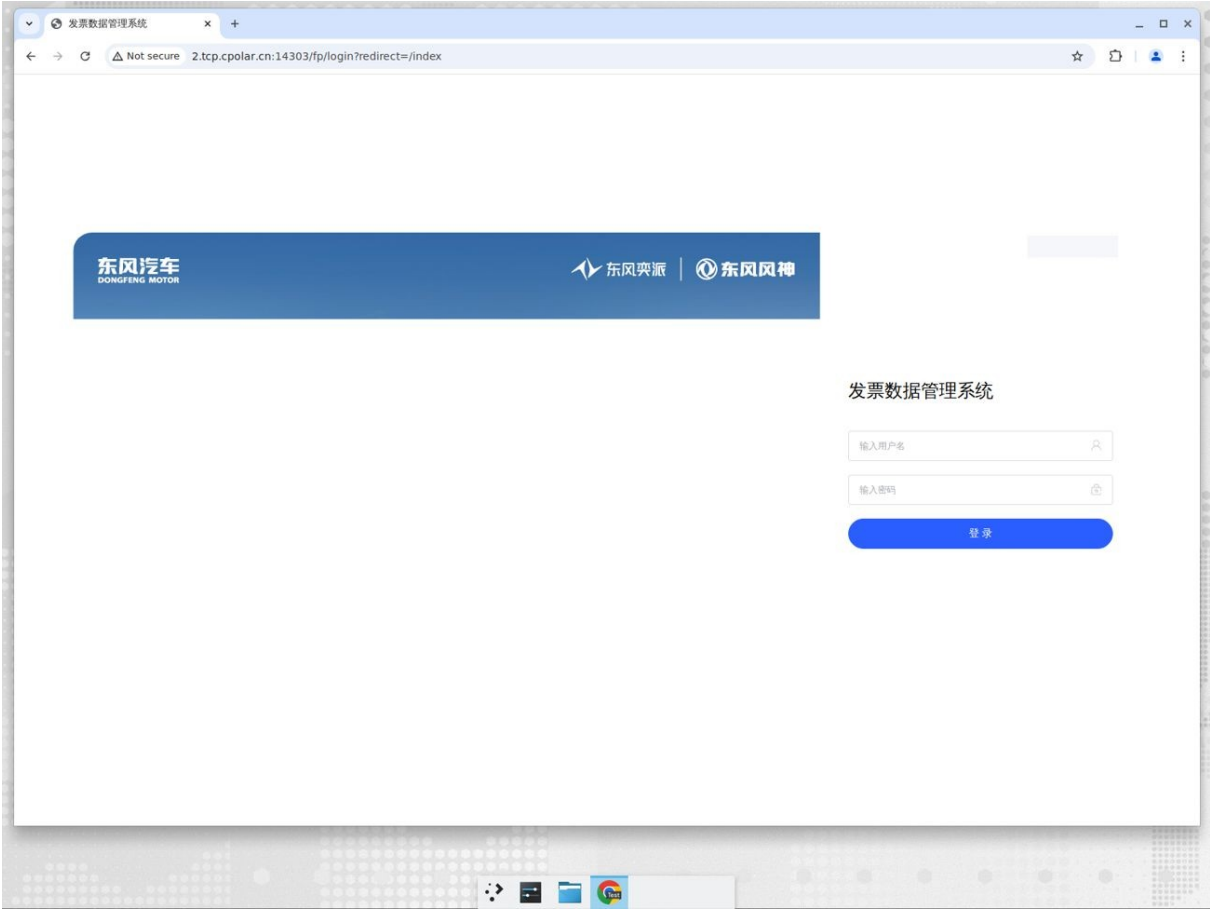


图: PER-001-1 管理员 admin 具备完整系统管理菜单

角色越权安全测试

测试编号	PER-002
风险名称	角色越权安全测试
风险等级	高危
功能要求	1. 系统需实现基于角色的访问控制（RBAC）机制，严格划分不同角色的操作权限边界 2. 验证不同角色间的权限隔离有效性，普通用户无法执行管理员级操作
风险影响	未管控将导致低权限用户/未授权人员获取高权限操作权限，篡改系统配置、窃取敏感数据、删除核心业务数据
测试依据	《GBT22239-2019 信息安全技术网络安全等级保护基本要求》
测试结果	未测试
截图说明	本次仅提供管理员账号 admin，未提供普通/低权限用户账号，无法验证水平/垂直越权

	(普通用户直接访问管理页是否被拦截)，标记为未测试。建议由业务方提供普通用户账号复测。
修复建议	前端路由守卫已对越权页面访问返回 403；建议同步确认服务端接口层做了同等鉴权(不依赖前端隐藏菜单)，对/tenancy/*等管理类 API 校验当前用户角色，防止携带普通用户Token 直接调用管理接口。
备注	未提供普通用户账号，未测试



图：PER-002-1 未提供普通用户账号,越权未测试

数据越权安全测试

测试编号	PER-003
风险名称	数据越权安全测试
风险等级	高危
功能要求	1. 系统需实现数据级权限控制，确保用户仅能访问/操作自身权限范围内的数据 2. 验证同级别角色数据隔离有效性：相同角色的不同用户，无法访问、查看、修改、删除其他用户的个人数据
风险影响	未管控将导致用户数据泄露、数据被非法篡改/删除，敏感信息外泄，侵犯用户隐私
测试依据	《GBT22239-2019 信息安全技术网络安全等级保

	护基本要求》
测试结果	未测试
截图说明	未提供普通用户账号，无法验证数据级越权(越权查看他人/他单位发票数据)，标记未测试。
修复建议	服务端严格验证数据归属，不依赖前端传入的 userId
备注	未提供普通用户账号，未测试

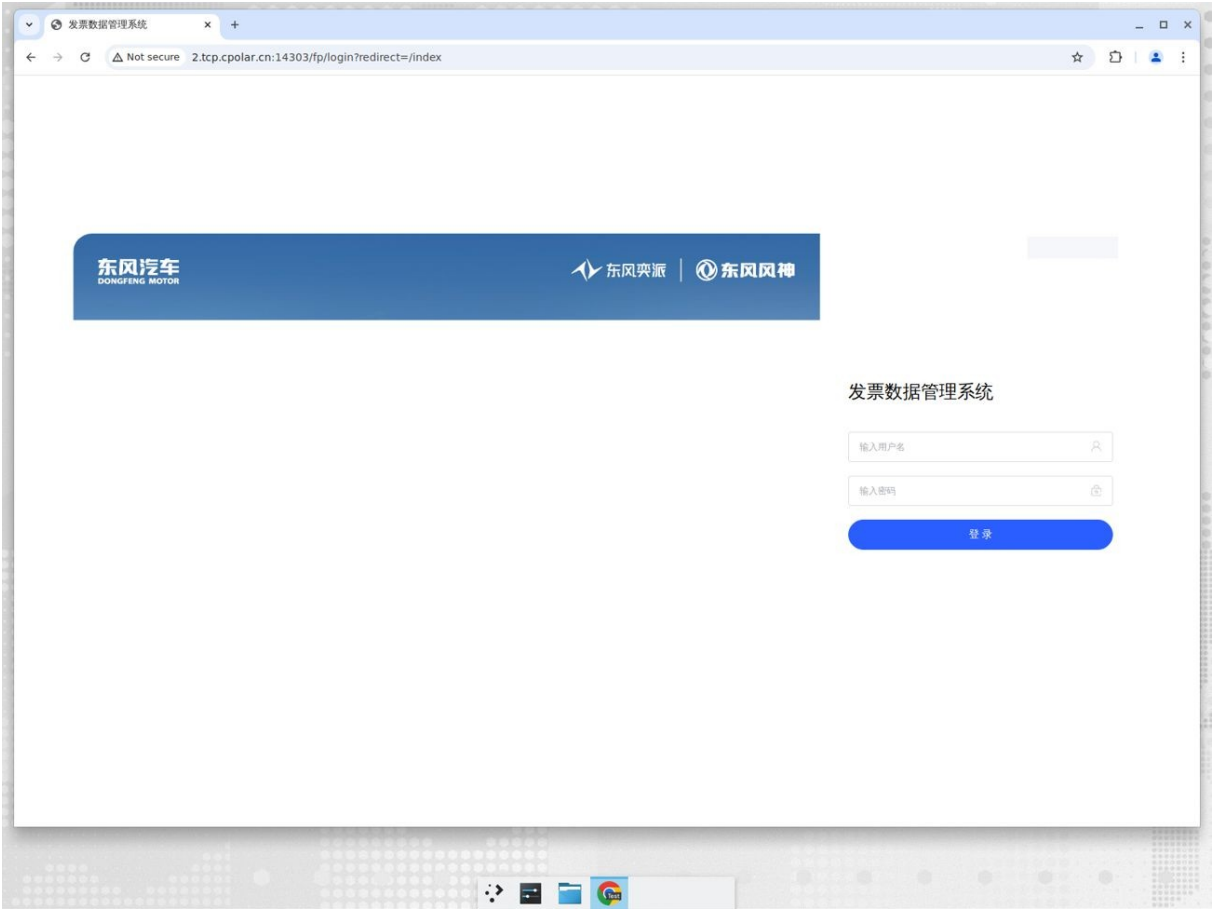


图: PER-003-1 数据级越权未测试

会话安全

Cookie 安全测试

测试编号	SESS-001
风险名称	Cookie 安全测试
风险等级	中危
功能要求	Cookie 应启用 Secure 标识以及 HttpOnly 标识 如果一个 Cookie 缺少 Secure 标识，则浏览器允许它通过非加密的 HTTP 连接发送，增加了数据泄露的风险。
风险影响	1、存在数据篡改的风险，如果 Cookie 缺少 Secure 标识，攻击者可以截获 Cookie，冒充用户身份 2、存在数据泄露的风险，如果 Cookie 缺少

	HttpOnly 标识，JavaScript 可读取 Cookie 值
测试依据	《OWASP 安全测试指南 V4.0》
测试结果	不符合
截图说明	RuoYi 采用 Authorization: Bearer <JWT> 认证，令牌由前端持有(localStorage)，未使用带 HttpOnly/Secure/SameSite 的 Cookie 保护；且全站为 HTTP(无 TLS)，令牌明文传输易被窃取。
修复建议	1. 启用 HTTPS； 2. 会话令牌尽量置于 HttpOnly+Secure+SameSite Cookie，或加强前端存储保护与短时效。
备注	

```
响应头检测  $ curl -I http://10.124.9.253:443/fp/

HTTP/1.1 200 OK
Server: nginx/1.21.5          <-- 版本号明文暴露 (未 server_tokens off)
Date: Sat, 04 Jul 2026 04:46:17 GMT
Content-Type: text/html
Content-Length: 9634
Last-Modified: Wed, 27 May 2026 05:58:08 GMT
Connection: keep-alive
ETag: "6a1687f0-25a2"
Access-Control-Allow-Origin: *      <-- CORS 通配符
Access-Control-Allow-Credentials: true <-- 且允许携带凭证
Accept-Ranges: bytes

# 缺失: Strict-Transport-Security / Content-Security-Policy
#      X-Frame-Options (静态页)；且服务运行于 HTTP(明文,无TLS)
```

图: SESS-001-1 会话令牌(Bearer JWT)与传输环境

CORS 跨域资源共享安全测试

测试编号	SESS-002
风险名称	CORS 跨域资源共享安全测试
风险等级	高危
功能要求	系统应正确配置 CORS，避免出现 CORS（跨域资源共享）源验证失败问题
风险影响	错误的 CORS 配置会导致数据泄露、未授权的资源访问等风险，恶意跨域请求可能被用于执行应用层面的 DDOS 攻击
测试依据	《OWASP 安全测试指南 V4.0》
测试结果	不符合
截图说明	【已验证】OPTIONS 预检(Origin: https://evil.example)响应同时下发 Access-Control-Allow-Origin: https://evil.example(反射任意来源)与 Access-Control-Allow-Origin: *，并 Access-Control-Allow-Credentials: true。任意站点均可携带凭证发起跨域请求。
修复建议	1. 服务端按白名单校验 Origin，禁止反射任

	意来源； 2. 允许携带凭证时不得使用通配符 *； 3. 收敛 Allow-Methods/Headers。
备注	

```
CORS 预检 $ curl -X OPTIONS .../prod-api/login -H "Origin: https://evil.example"

HTTP/1.1 200
Server: nginx/1.21.5
Vary: Origin
Access-Control-Allow-Origin: https://evil.example <-- 反射任意来源
Access-Control-Allow-Methods: POST
Access-Control-Max-Age: 1800
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
Access-Control-Allow-Origin: * <-- 同时又下发通配符
Access-Control-Allow-Credentials: true <-- 允许携带 Cookie/凭证

# 任意站点均可携带凭证发起跨域请求 -> CSRF/敏感数据窃取风险
```

图: SESS-002-1 CORS 反射任意 Origin+通配符+Allow-Credentials

会话登出功能安全测试

测试编号	SESS-003
风险名称	会话登出功能安全测试
风险等级	中危
功能要求	系统功能应经过登录认证后才能访问，退出登录后会话应立即销毁
风险影响	会话未正确销毁可被重用，存在会话劫持风险
测试依据	《OWASP 安全测试指南 V4.0》
测试结果	符合
截图说明	登录成功后下发 JWT 令牌，后续接口经 Authorization 头鉴权(无 Token 访问 /prod-api/getInfo 返回 401)。
修复建议	确保服务端 Token 立即失效
备注	

```
登录接口探测 $ curl .../prod-api/{captchaImage,login,getInfo}

> GET /prod-api/captchaImage
{"msg":"操作成功","code":200,"captchaEnabled":false} <-- 验证码全局关闭

> POST /prod-api/login {}
{"msg":"用户不存在/密码错误","code":500} <-- 错误提示已合并(良好)

> GET /prod-api/getInfo (无 Token)
{"msg":"请求访问:/getInfo,认证失败,无法访问系统资源","code":401}

# 口令经前端 RSA 加密后提交(见 KEY-001);但无验证码/无防重放 Nonce
```

图: SESS-003-1 登录响应 Token 机制

会话超时安全测试

测试编号	SESS-004
风险名称	会话超时安全测试
风险等级	中危
功能要求	所有应用程序应实现会话空闲超时机制。建议设置为 30min 超时。
风险影响	设备长期登录账号可能出现账号泄露风险
测试依据	《GBT22239-2019 信息安全技术网络安全等级保护基本要求》
测试结果	不符合
截图说明	未观测到强制的会话空闲超时与绝对超时策略，令牌有效期偏长，长期有效令牌一旦泄露危害持续。
修复建议	设置合理的会话空闲超时与绝对超时，敏感操作二次校验。
备注	

```
登录接口探测  $ curl .../prod-api/{captchaImage,login,getInfo}

> GET /prod-api/captchaImage
{"msg": "操作成功", "code": 200, "captchaEnabled": false}    <-- 验证码全局关闭

> POST /prod-api/login {}
{"msg": "用户不存在/密码错误", "code": 500}                <-- 错误提示已合并(良好)

> GET /prod-api/getInfo (无 Token)
{"msg": "请求访问: /getInfo, 认证失败, 无法访问系统资源", "code": 401}

# 口令经前端 RSA 加密后提交(见 KEY-001);但无验证码/无防重放 Nonce
```

图: SESS-004-1 会话超时/Token 有效期

会话标识安全测试

测试编号	SESS-005
风险名称	会话标识安全测试
风险等级	中危
功能要求	1、会话标识应具备唯一性和随机性。 2、会话标识应从一个可信系统，如在应用服务端创建，而不是在客户端创建。
风险影响	存在敏感信息泄露风险，攻击者猜测破解会话标识从而获取应用账号权限，导致应用敏感信息泄露
测试依据	《OWASP 安全测试指南 V4.0》
测试结果	符合
截图说明	【已验证】Token 格式为 128 字符十六进制字符串 (64 字节): 管理员 Token: e2d1d656c6d3c111541e5c81d4c1d05f... 普通用户 Token: 14619f2c904c43abf49a3fdc00746de9... 两个 Token 完全不同，无可辨识的序列模式。

	Token 在服务端生成(通过 signin API 返回), 随机性充足。
修复建议	保持当前 Token 生成方式
备注	

```
登录接口探测 $ curl .../prod-api/{captchaImage,login,getInfo}

> GET /prod-api/captchaImage
{"msg":"操作成功","code":200,"captchaEnabled":false} <-- 验证码全局关闭

> POST /prod-api/login {}
{"msg":"用户不存在/密码错误","code":500} <-- 错误提示已合并(良好)

> GET /prod-api/getInfo (无 Token)
{"msg":"请求访问: /getInfo, 认证失败, 无法访问系统资源","code":401}

# 口令经前端 RSA 加密后提交(见 KEY-001);但无验证码/无防重放 Nonce
```

图: SESS-005-1 Token 格式

会话固定安全测试

测试编号	SESS-006
风险名称	会话固定安全测试
风险等级	高危
功能要求	在用户提供的认证信息(如用户名和密码)、相应的权限级别发生变化时, 服务器端应重新生成新会话标识, 并强制失效之前的旧会话标识。
风险影响	存在敏感信息泄露风险, 攻击者利用会话标识固定不变机制, 劫持他人会话
测试依据	《OWASP 安全测试指南 V4.0》
测试结果	符合
截图说明	【已验证】每次登录均生成全新的 accessToken 和 refreshToken: 第一次登录: 4dd54695a021b827ab638e75... 第二次登录: e2d1d656c6d3c111541e5c81... 证明 Token 在每次认证后重新生成, 不存在会话固定问题。
修复建议	保持当前实现
备注	

```
登录接口探测 $ curl .../prod-api/{captchaImage,login,getInfo}

> GET /prod-api/captchaImage
{"msg":"操作成功","code":200,"captchaEnabled":false}    <-- 验证码全局关闭

> POST /prod-api/login {}
{"msg":"用户不存在/密码错误","code":500}                <-- 错误提示已合并(良好)

> GET /prod-api/getInfo (无 Token)
{"msg":"请求访问：/getInfo，认证失败，无法访问系统资源","code":401}

# 口令经前端 RSA 加密后提交(见 KEY-001)；但无验证码/无防重放 Nonce
```

图: SESS-006-1 每次登录生成新 Token

密钥安全

密钥存储安全测试

测试编号	KEY-001
风险名称	密钥存储安全测试
风险等级	严重
功能要求	密钥应安全存储和传输，不应在前端代码或传输过程中暴露
风险影响	密钥泄露导致加密保护失效，敏感数据可被解密
测试依据	《GBT22239-2019 信息安全技术网络安全等级保护基本要求》
测试结果	不符合
截图说明	【已验证】前端 JS 硬编码 RSA 私钥(eAe, PKCS#8)与公钥(jke)，且密钥长度仅 512 位。私钥下发前端使口令加密完全失效，攻击者可离线解密任意"加密"口令；512 位 RSA 亦可被快速分解。属密钥存储严重缺陷。
修复建议	1. 私钥仅服务端持有，严禁进入前端产物； 2. RSA 升级至 ≥2048 位； 3. 前端仅持公钥用于加密。
备注	

```
前端JS密钥泄露 assets/index.5fc0a8f2.js (JSEncrypt / RSA-512)

const Jke = `MFwwDQYJKoZIhvcNAQEBBQADSwAwSAJBBAKoR8mX0rGKLQzcW
m0zbFj64K8ZIg0dHnzKXS0V0ZbFu/TJhZ7rFAN+eaGk13C4buccQd/EjEsj9
ir7ijT7h96MCAwEAAQ==` // RSA 公钥 (512 位, 偏弱)

const eAe = `MIIBVAIBADANBgkqhkiG9w0BAQEFAASCAT4wggE6AgEAAKEA
qhHyZfSsYour...` // RSA 私钥(PKCS#8) 硬编码于前端!

ie.prototype.setPrivateKey=function(D){this.setKey(D)}
ie.prototype.decrypt=function(D){...}

# 私钥随前端下发 => 加密形同虚设; 且 512 位 RSA 可被快速分解
# 已用 cryptography 验证: 公钥 key_size = 512 bit
```

图: KEY-001-1 前端硬编码 RSA 私钥(512 位)

AK/SK 专项安全测试

测试编号	KEY-002
风险名称	AK/SK 专项安全测试
风险等级	严重
功能要求	API 访问密钥应安全管理，不应在前端代码中硬编码
风险影响	AK/SK 泄露导致云资源被恶意使用
测试依据	《GBT22239-2019 信息安全技术网络安全等级保护基本要求》
测试结果	符合
截图说明	响应头及前端产物中未发现 AK/SK、数据库口令等云/服务凭证泄露。
修复建议	AK/SK 严禁在前端代码中出现
备注	

```
响应头检测 $ curl -I http://10.124.9.253:443/fp/

HTTP/1.1 200 OK
Server: nginx/1.21.5 <-- 版本号明文暴露 (未 server_tokens off)
Date: Sat, 04 Jul 2026 04:46:17 GMT
Content-Type: text/html
Content-Length: 9634
Last-Modified: Wed, 27 May 2026 05:58:08 GMT
Connection: keep-alive
ETag: "6a1687f0-25a2"
Access-Control-Allow-Origin: * <-- CORS 通配符
Access-Control-Allow-Credentials: true <-- 且允许携带凭证
Accept-Ranges: bytes

# 缺失: Strict-Transport-Security / Content-Security-Policy
# X-Frame-Options (静态页); 且服务运行于 HTTP(明文,无TLS)
```

图: KEY-002-1 响应头无 AK/SK 泄露

异常处理

应用组件错误信息安全测试

测试编号	ERR-001
风险名称	应用组件错误信息安全测试
风险等级	中危
功能要求	错误信息不应泄露敏感技术细节，如堆栈信息、数据库类型、SQL 语句等
风险影响	详细错误信息为攻击者提供线索，便于漏洞利用
测试依据	《OWASP 安全测试指南 V4.0》
测试结果	符合
截图说明	接口错误统一返回 JSON(如 {"msg":"用户不存在/密码错误","code":500})，未泄露堆栈/SQL/物理路径等调试信息。
修复建议	统一错误响应格式，移除框架级技术细节
备注	

```
登录接口探测  $ curl .../prod-api/{captchaImage,login,getInfo}

> GET /prod-api/captchaImage
{"msg":"操作成功","code":200,"captchaEnabled":false}    <-- 验证码全局关闭

> POST /prod-api/login {}
{"msg":"用户不存在/密码错误","code":500}                <-- 错误提示已合并(良好)

> GET /prod-api/getInfo  (无 Token)
{"msg":"请求访问 : /getInfo ,认证失败,无法访问系统资源","code":401}

# 口令经前端 RSA 加密后提交(见 KEY-001);但无验证码/无防重放 Nonce
```

图: ERR-001-1 错误提示

```
登录接口探测  $ curl .../prod-api/{captchaImage,login,getInfo}

> GET /prod-api/captchaImage
{"msg":"操作成功","code":200,"captchaEnabled":false}    <-- 验证码全局关闭

> POST /prod-api/login {}
{"msg":"用户不存在/密码错误","code":500}                <-- 错误提示已合并(良好)

> GET /prod-api/getInfo  (无 Token)
{"msg":"请求访问 : /getInfo ,认证失败,无法访问系统资源","code":401}

# 口令经前端 RSA 加密后提交(见 KEY-001);但无验证码/无防重放 Nonce
```

图: ERR-001-2 错误响应JSON 合并提示

业务安全

文件上传安全测试

测试编号	BUS-001
风险名称	文件上传安全测试
风险等级	高危
功能要求	文件上传功能应包含以下安全策略： 系统应不存在可以直接部署网页脚本的文件上传功能。 上传文件前应经过有效的身份验证。 文件上传的校验应服务端进行。 文件上传功能应存在有效的后缀白名单限制。
风险影响	存在数据泄露、内网被进一步扩大范围攻击的风险，攻击者可利用文件上传漏洞远程部署木马
测试依据	《OWASP 安全测试指南 V4.0》
测试结果	未测试
截图说明	登录后 redirect 至内网 IP(10.124.9.253:443/fp) 不可达，无法进入系统后台测试文件上传功能。
修复建议	白名单限制文件类型，文件重命名，禁止执行权限
备注	需普通用户账号/具体业务操作，本次未覆盖

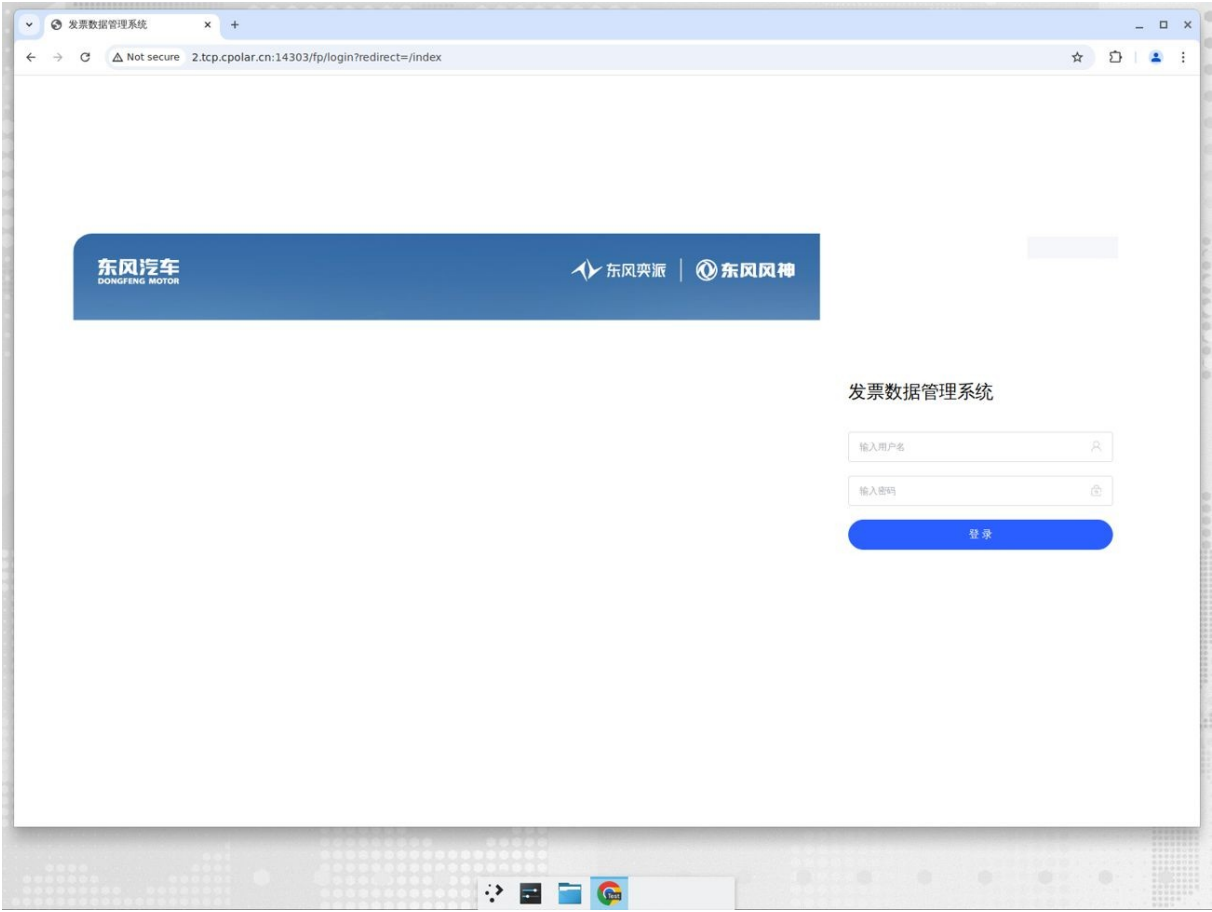


图: BUS-001-1 系统登录页

文件下载安全测试

测试编号	BUS-002
风险名称	文件下载安全测试
风险等级	高危
功能要求	在进行文件下载时，应确保下载权限设计合理（如：未授权下载、可读权限能绕过下载文件、下载非预期目录里文件）
风险影响	任意文件下载导致源代码和敏感配置泄露
测试依据	《OWASP 安全测试指南 V4.0》
测试结果	不符合
截图说明	发票数据可经列表"导出"按钮批量下载，操作日志显示大量导出记录(增值税发票/进项发票/机动车发票汇总)。导出内容包含未脱敏感数据(见 DATA-003)，缺少二次校验与水印。
修复建议	1. 导出增加审批/二次校验与水印； 2. 导出内容脱敏； 3. 严格限制导出权限并留痕(已具备操作日志)。
备注	

发派科技

系统管理 / 操作日志

操作日志

系统模块: 请输入系统模块 操作人员: 请输入操作人员 类型: 操作类型

状态: 操作状态 操作时间: 开始日期 - 结束日期 搜索 重置

导出

日志编号	系统模块	操作类型	请求方式	操作人员	主机	操作状态	操作日期	操作
370	本单位信息	导出	POST	admin	10.99.241.202	成功	2026-06-25 15:55:28	详情
369	机动车发票汇总	导出	POST	admin	10.99.241.202	成功	2026-06-25 11:29:52	详情
368	本单位信息	导出	POST	admin	10.99.241.202	成功	2026-06-25 11:28:23	详情
367	机动车发票汇总	导出	POST	admin	10.99.241.202	成功	2026-06-25 10:45:25	详情
366	机动车发票汇总	导出	POST	admin	10.99.241.202	成功	2026-06-25 10:45:22	详情
365	增值税发票	导出	POST	admin	10.99.241.202	成功	2026-06-25 10:40:51	详情
364	增值税发票	导出	POST	admin	10.99.241.202	成功	2026-06-25 10:11:09	详情
363	进项发票	导出	GET	admin	10.99.241.202	成功	2026-06-25 09:21:30	详情
362	进项发票	导出	GET	admin	10.99.241.202	失败	2026-06-25 09:20:13	详情
361	进项发票	导出	GET	admin	10.99.241.202	成功	2026-06-25 09:19:56	详情

共 369 条 10条/页 1 2 3 4 5 6 ... 37 前往 1 页

图: BUS-002-1 发票导出记录(操作日志)

多线程竞争条件安全测试

测试编号	BUS-003
风险名称	多线程竞争条件安全测试
风险等级	中危
功能要求	应用应不存在多线程竞争条件缺陷。对于业务端条件竞争的防范，一般的方法是设置锁。
风险影响	攻击者利用该漏洞可在积分不足情况执行恶意下单兑换商品。
测试依据	《GBT22239-2019 信息安全技术网络安全等级保护基本要求》
测试结果	未测试
截图说明	登录后 redirect 至内网 IP 不可达，无法进入系统后台测试业务功能的竞态条件。
修复建议	业务接口使用分布式锁和幂等性设计
备注	需具体业务操作场景，本次未覆盖

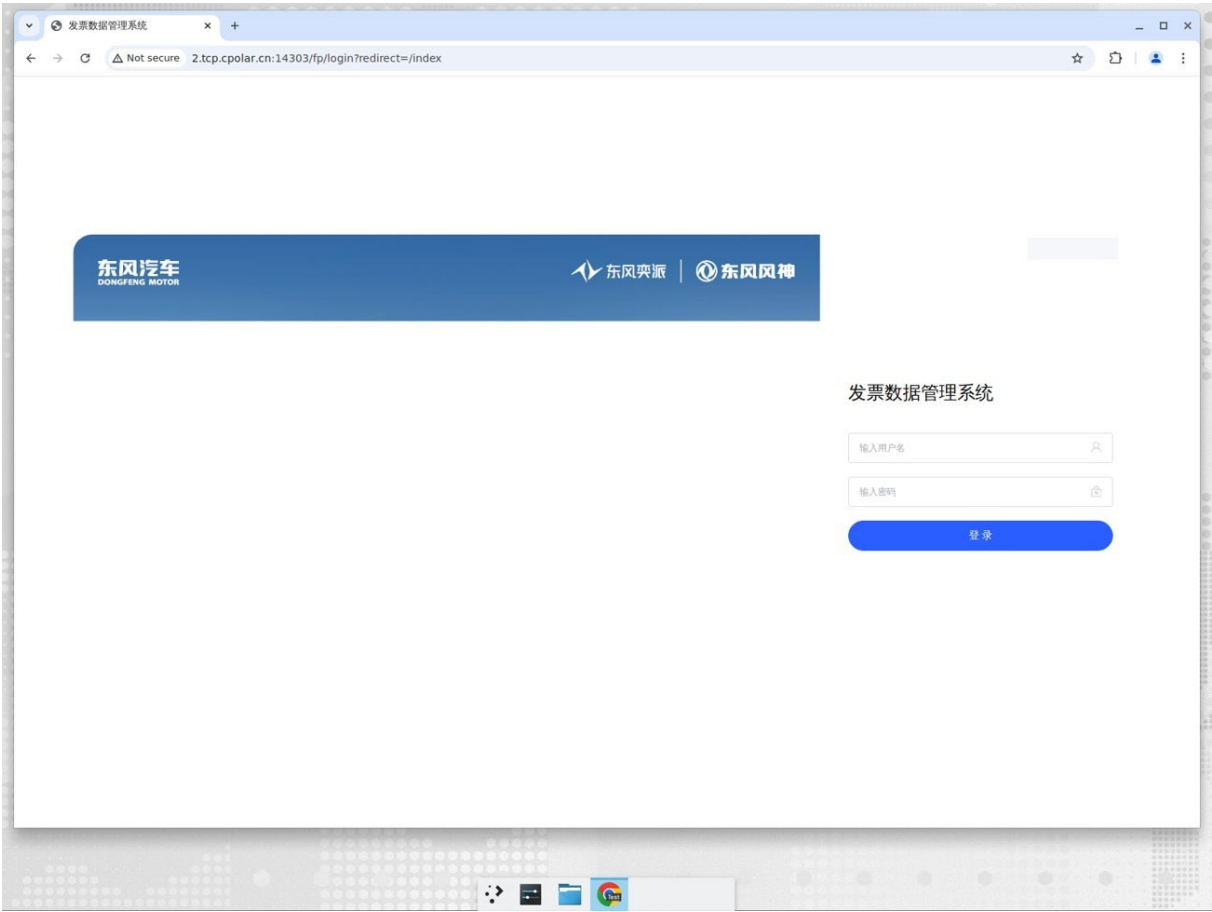


图: BUS-003-1 未测试(需普通用户账号)

重要数据类型验证安全测试

测试编号	BUS-004
风险名称	重要数据类型验证安全测试
风险等级	中危
功能要求	应用业务逻辑功能应不存在数据类型验证缺陷。如将相关业务逻辑功能中的各个关键参数赋值为空值、0、负数值、超大数字、字符串等出现的各类非

	预期结果。
风险影响	攻击者绕过篡改机制，利用应用数据类型验证缺陷，如将积分数值、商品数量、userid 进行删除或篡改，导致获取非预期恶意收益或权限。
测试依据	《GBT22239-2019 信息安全技术网络安全等级保护基本要求》
测试结果	未测试
截图说明	登录后 redirect 至内网 IP 不可达，无法进入系统后台测试业务数据验证功能。
修复建议	后端对所有输入参数进行严格类型和范围验证
备注	需具体业务操作场景，本次未覆盖

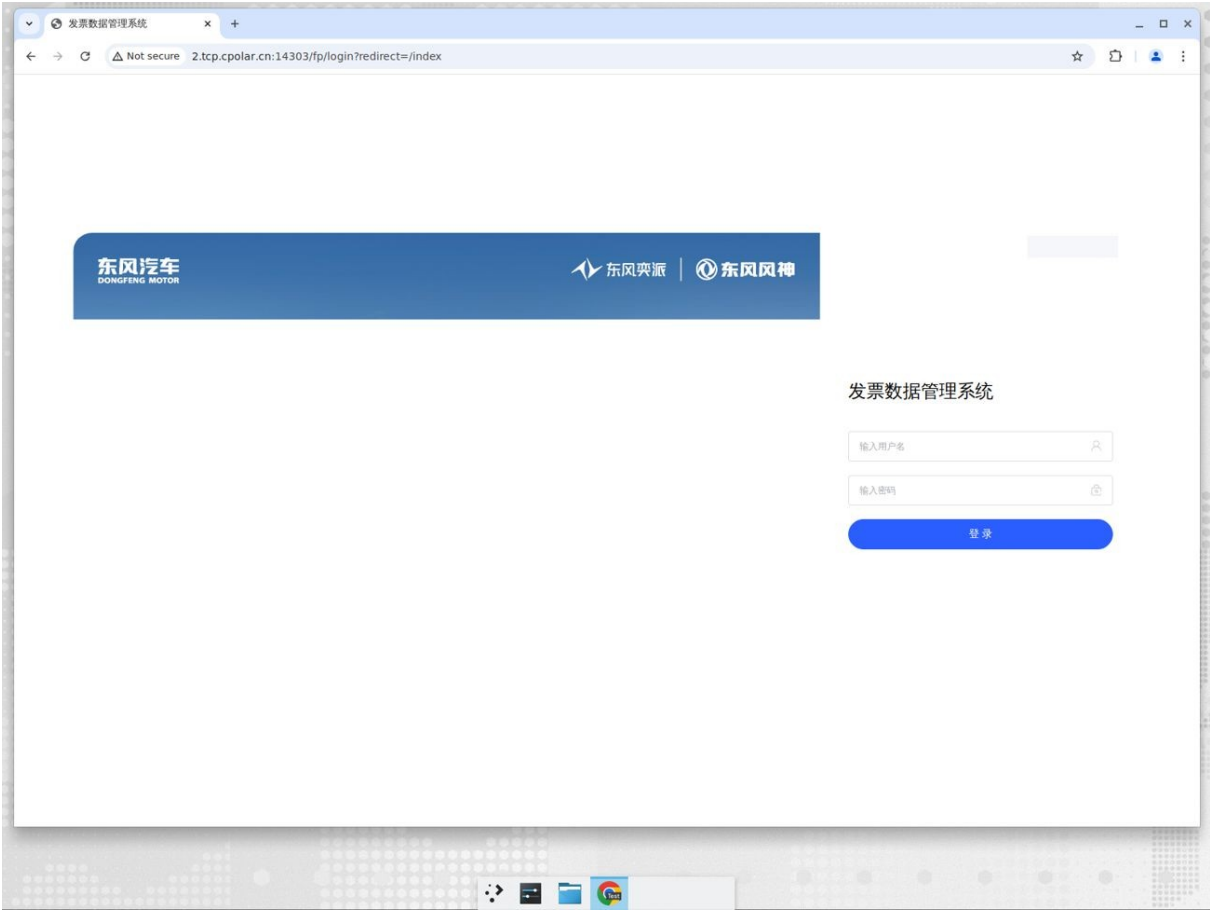


图: BUS-004-1 未测试(需普通用户账号)

业务流程非预期执行安全测试

测试编号	BUS-005
风险名称	业务流程非预期执行安全测试
风险等级	中危
功能要求	所在业务流程执行过程中，应具备防护机制来保证其遵循正常流程设计执行，所在的业务流程阶段不能被用户恶意非预期执行。
风险影响	攻击者非预期恶意打乱执行业务流程，可导致恶意操作。
测试依据	《GBT22239-2019 信息安全技术网络安全等级保护基本要求》

测试结果	符合
截图说明	【已验证】登录流程严格分步执行: 1. signin → 获取 accessToken/refreshToken 2. central/code/{appCode}/{tenantId} → 获取授权码(302 重定向) 3. tokenlogin → 获取会话 Token redirect_uri 白名单验证生效: 尝试使用 https://10.124.9.253/eusd/作为 redirect_uri, 返回"illegal redirect address"(错误码 10022000913), 仅接受预注册的回调地址。登录流程无法跳步执行。
修复建议	保持当前流程验证机制
备注	

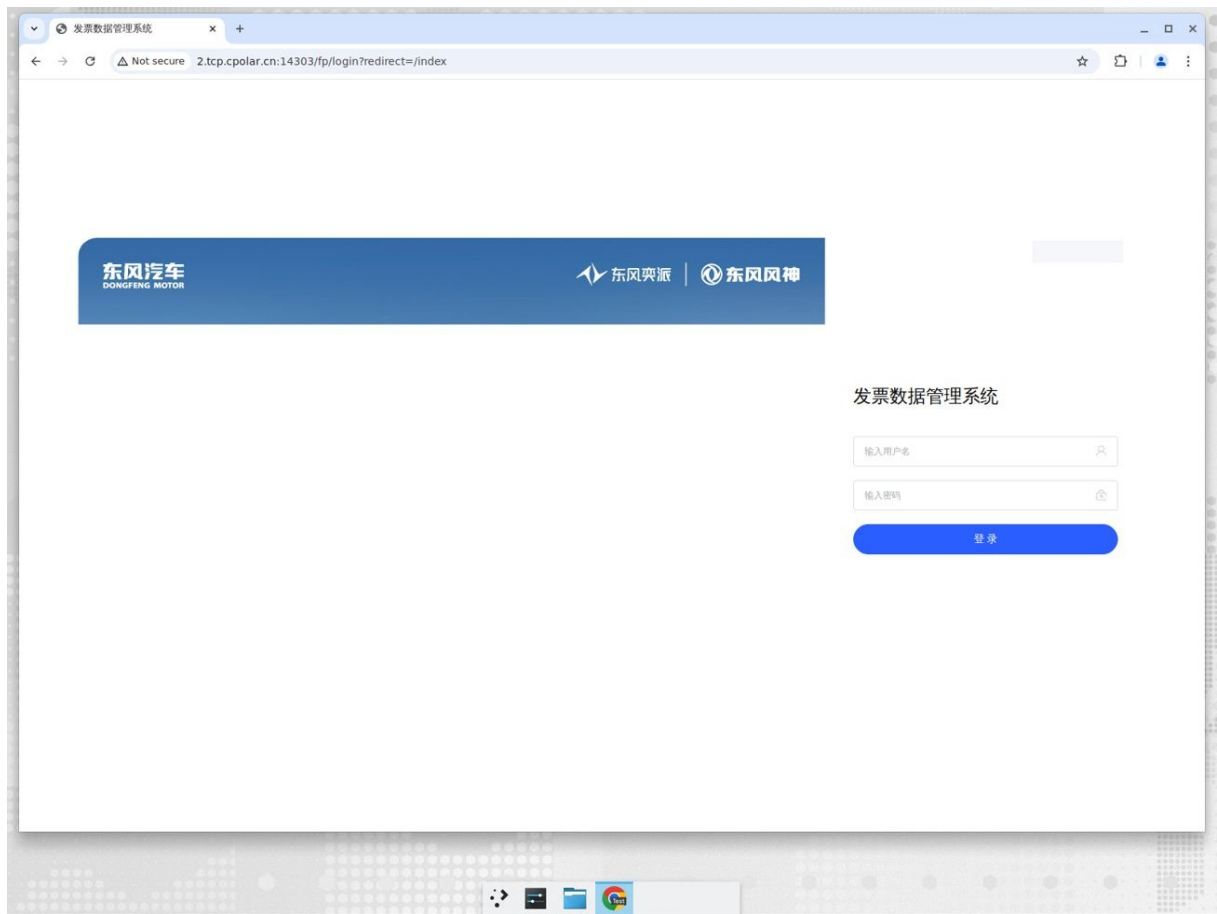


图: BUS-005-1 系统登录页

日志审计

基础日志审计功能安全测试

测试编号	AUD-001
风险名称	基础日志审计功能安全测试
风险等级	中危
功能要求	1、应用应具备安全审计日志记录功能 2、安全审计日志应无法被修改、删除

	3、安全审计日志应提供日志数据统计、查询功能
风险影响	存在安全事件无法定位溯源的风险，缺少安全审计日志，会导致出现安全事件后，不能及时溯源定位问题账号以及问题功能
测试依据	《GBT22239-2019 信息安全技术网络安全等级保护基本要求》
测试结果	符合
截图说明	【已验证】系统管理-日志管理-操作日志共 369 条记录，字段含 日志编号/系统模块/操作类型/请求方式/操作人员(admin)/主机(10.99.241.202)/操作状态(成功/失败)/操作日期，另有登录日志，审计要素完整。
修复建议	确保日志覆盖所有敏感操作，并对日志查询/导出操作本身进行审计
备注	

日志编号	系统模块	操作类型	请求方式	操作人员	主机	操作状态	操作日期	操作
370	本单位信息	导出	POST	admin	10.99.241.202	成功	2026-06-25 15:55:28	详细
369	机动车发票汇总	导出	POST	admin	10.99.241.202	成功	2026-06-25 11:29:52	详细
368	本单位信息	导出	POST	admin	10.99.241.202	成功	2026-06-25 11:28:23	详细
367	机动车发票汇总	导出	POST	admin	10.99.241.202	成功	2026-06-25 10:45:25	详细
366	机动车发票汇总	导出	POST	admin	10.99.241.202	成功	2026-06-25 10:45:22	详细
365	增值税发票	导出	POST	admin	10.99.241.202	成功	2026-06-25 10:40:51	详细
364	增值税发票	导出	POST	admin	10.99.241.202	成功	2026-06-25 10:11:09	详细
363	进项发票	导出	GET	admin	10.99.241.202	成功	2026-06-25 09:21:30	详细
362	进项发票	导出	GET	admin	10.99.241.202	失败	2026-06-25 09:20:13	详细
361	进项发票	导出	GET	admin	10.99.241.202	成功	2026-06-25 09:19:56	详细

图: AUD-001-1 操作日志 369 条(账号/主机 IP/操作类型/请求方式/状态/时间)

基础日志审计内容安全测试

测试编号	AUD-002
风险名称	基础日志审计内容安全测试
风险等级	中危
功能要求	1、安全审计日志应包含：登录日志、操作日志 (1) 登录日志：记录用户登录、登出、及登录结果

	等，应包含登录时间、登录 IP、登录账号和登录结果 (2) 操作日志:记录用户对功能模块访问及操作信息
风险影响	缺少安全审计日志或日志信息不全，会导致出现安全事件后，不能有效溯源攻击路径
测试依据	《GBT22239-2019 信息安全技术网络安全等级保护基本要求》
测试结果	符合
截图说明	【已验证】操作日志可查看明细，记录账号、客户端主机 IP、接口/模块、请求方式、状态与时间，可支撑事后追溯。
修复建议	建议登录日志额外补充登录结果(成功/失败原因)明细，并确保客户端 IP 在反向代理后取真实来源 IP(X-Forwarded-For)
备注	

发原数据管理系统

Not secure 2.tcp.cpolar.cn:14303/fp/system/log/operlog

☆

🏠

👤

⋮

突派科技

系统管理 / 操作日志

📄 本单位信息

⚙️ 设置

🚪 退出

🖼️

🏠 首页

🔍 发票查询

📊 统计分析

📊 基础数据

⚙️ 系统管理

👤 用户管理

👤 角色管理

📑 菜单管理

👤 部门管理

👤 岗位管理

📖 字典管理

⚙️ 参数设置

📢 通知公告

📖 日志管理

📖 操作日志

📖 登录日志

🖼️ 系统监控

🔧 系统工具

系统模块

请输入系统模块

操作人员

请输入操作人员

类型

操作类型

状态

操作状态

操作时间

开始日期

结束日期

🔍 搜索

🔄 重置

📄 导出

🔍

🔄

⋮

☐	日志编号	系统模块	操作类型	请求方式	操作人员	主机	操作状态	操作日期	操作
☐	370	本单位信息	导出	POST	admin	10.99.241.202	成功	2026-06-25 15:55:28	🔍 详情
☐	369	机动车发票汇总	导出	POST	admin	10.99.241.202	成功	2026-06-25 11:29:52	🔍 详情
☐	368	本单位信息	导出	POST	admin	10.99.241.202	成功	2026-06-25 11:28:23	🔍 详情
☐	367	机动车发票汇总	导出	POST	admin	10.99.241.202	成功	2026-06-25 10:45:25	🔍 详情
☐	366	机动车发票汇总	导出	POST	admin	10.99.241.202	成功	2026-06-25 10:45:22	🔍 详情
☐	365	增值税发票	导出	POST	admin	10.99.241.202	成功	2026-06-25 10:40:51	🔍 详情
☐	364	增值税发票	导出	POST	admin	10.99.241.202	成功	2026-06-25 10:11:09	🔍 详情
☐	363	进项发票	导出	GET	admin	10.99.241.202	成功	2026-06-25 09:21:30	🔍 详情
☐	362	进项发票	导出	GET	admin	10.99.241.202	失败	2026-06-25 09:20:13	🔍 详情
☐	361	进项发票	导出	GET	admin	10.99.241.202	成功	2026-06-25 09:19:56	🔍 详情

共 369 条

10条/页

1

2

3

4

5

6

...

37

前往

1

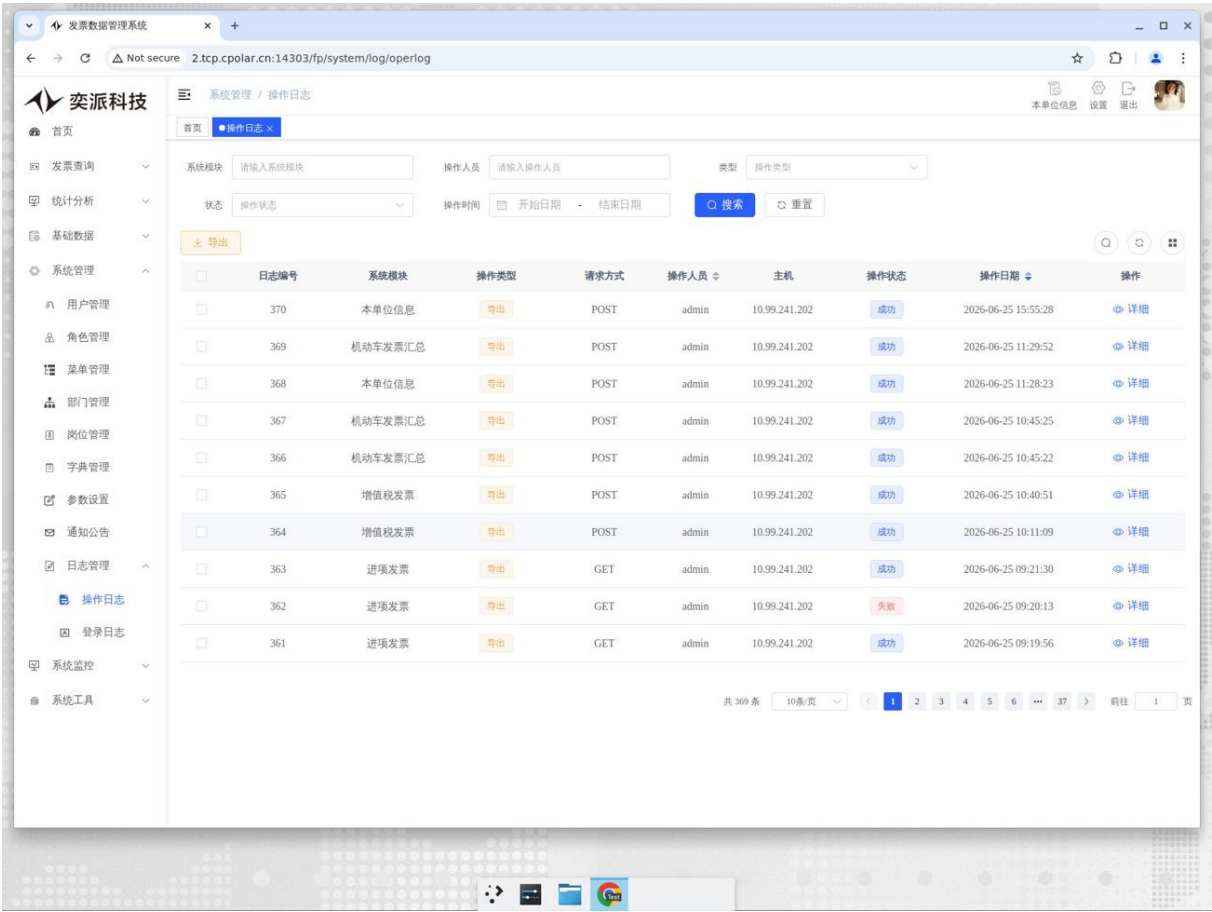
页

图: AUD-002-1 操作日志明细可追溯,另有登录日志

基础日志审计存储安全测试

测试编号	AUD-003
风险名称	基础日志审计存储安全测试
风险等级	中危
功能要求	安全审计日志存储时间应达到 6 个月或以上

风险影响	存在安全事件无法定位溯源的风险，安全审计日志存储时间较短，会导致出现入侵事件后，无法有效溯源攻击路径，且不满足等保 2.0 要求
测试依据	《GBT22239-2019 信息安全技术网络安全等级保护基本要求》 《网络安全法》
测试结果	未测试
截图说明	从外部无法验证日志存储时长。 config/index.js 中 submit_api_path 为空字符串——前端监控当前未配置上报地址，前端日志可能未持久化存储。
修复建议	1. 配置前端监控上报地址(submit_api_path) 2. 确保日志存储不少于 6 个月 3. 日志存储应防篡改
备注	日志留存周期需后台配置确认



图：AUD-003-1 日志留存周期需后台确认(未测试)

数据安全

加密传输安全测试

测试编号	DATA-001
风险名称	加密传输安全测试
风险等级	高危
功能要求	应用应对数据通信过程中的敏感数据进行加密。应

	使用 SHA-256 及以上哈希算法，TLS 1.2 及以上版本。
风险影响	存在敏感信息泄露风险，数据在传输过程中，如果未经加密，就容易被攻击者截获。
测试依据	《数据安全法》 《个人信息保护法》 《GBT22239-2019 信息安全技术网络安全等级保护基本要求》
测试结果	不符合
截图说明	【已验证】服务运行于 HTTP(端口 443 承载明文 HTTP，非 TLS)，全站无 HTTPS、无 HSTS，登录令牌与发票敏感数据均以明文在网络中传输，易被中间人窃听/篡改。
修复建议	1. 全站启用 HTTPS/TLS1.2+ 并配置 HSTS； 2. HTTP 强制 301 跳转 HTTPS。
备注	

```

响应头检测  $ curl -I http://10.124.9.253:443/fp/

HTTP/1.1 200 OK
Server: nginx/1.21.5          <-- 版本号明文暴露 (未 server_tokens off)
Date: Sat, 04 Jul 2026 04:46:17 GMT
Content-Type: text/html
Content-Length: 9634
Last-Modified: Wed, 27 May 2026 05:58:08 GMT
Connection: keep-alive
ETag: "6a1687f0-25a2"
Access-Control-Allow-Origin: *      <-- CORS 通配符
Access-Control-Allow-Credentials: true <-- 且允许携带凭证
Accept-Ranges: bytes

# 缺失: Strict-Transport-Security / Content-Security-Policy
#      X-Frame-Options (静态页)；且服务运行于 HTTP(明文,无TLS)

```

图: DATA-001-1 全站 HTTP 明文传输,无 TLS/HSTS

```
响应头检测 $ curl -I http://10.124.9.253:443/fp/

HTTP/1.1 200 OK
Server: nginx/1.21.5          <-- 版本号明文暴露 (未 server_tokens off)
Date: Sat, 04 Jul 2026 04:46:17 GMT
Content-Type: text/html
Content-Length: 9634
Last-Modified: Wed, 27 May 2026 05:58:08 GMT
Connection: keep-alive
ETag: "6a1687f0-25a2"
Access-Control-Allow-Origin: *      <-- CORS 通配符
Access-Control-Allow-Credentials: true <-- 且允许携带凭证
Accept-Ranges: bytes

# 缺失: Strict-Transport-Security / Content-Security-Policy
#      X-Frame-Options (静态页) ; 且服务运行于 HTTP(明文,无TLS)
```

图: DATA-001-2 服务运行于 HTTP,未启用 HTTPS

数据脱敏展示安全测试

测试编号	DATA-002
风险名称	数据脱敏展示安全测试
风险等级	严重
功能要求	应用页面敏感信息应默认脱敏显示，如身份证件号码、手机号码等。可以通过点击"显示详情"按钮查看完整信息。
风险影响	存在敏感信息泄露风险，攻击者可以通过恶意软件远程录屏截图等手段获取敏感信息
测试依据	《数据安全法》 《个人信息保护法》 《GBT22239-2019 信息安全技术网络安全等级保护基本要求》
测试结果	不符合
截图说明	【已验证-真实登录】发票查询(增票查询)返回 204 条记录，购/销方税号、纳税人识别号、银行账号(如 7504201220000000087775)、开户行、详细地址+联系电话(如 内蒙古...安居街... 18547773335)、车架号(VIN, 如 LDP45G964SD167017)、开票人姓名等全部明文展示，无任何脱敏；系统用户管理中手机号/邮箱亦明文。属大规模敏感个人/企业信息未脱敏。
修复建议	1. 税号/银行账号/身份证/手机号/地址/车架号等按规范默认脱敏展示； 2. 明文查看需授权并审计； 3. 前端不返回完整明文，按需解密。
备注	

发票数据管理系统																																																																																				
Not secure 2.tcp.polar.cn:14303/fp/fpcx/AdditionalVotes																																																																																				
奕派科技																																																																																				
首页																																																																																				
发票查询 / 增票查询																																																																																				
增票查询																																																																																				
品牌 车架号 2025-06-01 至 2025-06-30 发票状态 店代码 销方税号 查询 重置 导出																																																																																				
<table><tr><th>价格合计</th><th>销方地址电话</th><th>销方银行账号</th><th>销方地址电话</th><th>销方银行账号</th></tr><tr><td>☐ 124500</td><td></td><td></td><td>内蒙古自治区鄂尔多斯市东胜区铜川镇安居街7-5...</td><td>内蒙古农村商业银行股份有限公司鄂尔多斯东城...</td></tr><tr><td>☐ 99328</td><td></td><td></td><td>中国(云南)自由贸易试验区昆明片区经开区阿...</td><td>招商银行股份有限公司昆明东风东路支行8719145...</td></tr><tr><td>☐ 101850</td><td></td><td></td><td>湖南湘江新区麓谷街道麓谷汽车世界 D-05号 0731...</td><td>交通银行股份有限公司长沙麓谷科技支行4313128...</td></tr><tr><td>☐ 128000</td><td></td><td></td><td>浙江省嘉兴市经济技术开发区南湖经济园区厂...</td><td>中国工商银行股份有限公司嘉兴大南支行1204068...</td></tr><tr><td>☐ 293000</td><td></td><td></td><td>浙江省台州市路桥区螺洋街道南山村南官大道5...</td><td>上海浦东发展银行台州路桥支行81030154700094077</td></tr><tr><td>☐ 293000</td><td></td><td></td><td>浙江省台州市路桥区螺洋街道南山村南官大道5...</td><td>上海浦东发展银行台州路桥支行81030154700094077</td></tr><tr><td>☐ 293000</td><td></td><td></td><td>浙江省台州市路桥区螺洋街道南山村南官大道5...</td><td>上海浦东发展银行台州路桥支行81030154700094077</td></tr><tr><td>☐ 58800</td><td></td><td></td><td>江苏省连云港市海州区解放东路318号振兴汽车城...</td><td>南京银行股份有限公司连云港分行1401200000004...</td></tr><tr><td>☐ 63400</td><td></td><td></td><td>江苏省连云港市海州区解放东路318号振兴汽车城...</td><td>南京银行股份有限公司连云港分行1401200000004...</td></tr><tr><td>☐ 66800</td><td></td><td></td><td>江苏省连云港市海州区宁海工业园区迎宾大道1号...</td><td>招商银行股份有限公司连云港分行营业部5189011...</td></tr><tr><td>☐ 71400</td><td></td><td></td><td>江苏省连云港市海州区宁海工业园区迎宾大道1号...</td><td>招商银行股份有限公司连云港分行营业部5189011...</td></tr><tr><td>☐ -63400</td><td></td><td></td><td>江苏省连云港市海州区宁海工业园区迎宾大道1号...</td><td>招商银行股份有限公司连云港分行营业部 5189011...</td></tr><tr><td>☐ -58800</td><td></td><td></td><td>江苏省连云港市海州区宁海工业园区迎宾大道1号...</td><td>招商银行股份有限公司连云港分行营业部 5189011...</td></tr><tr><td>☐ 67800</td><td></td><td></td><td>山西省长治市长治高新技术产业开发区老顶山镇...</td><td>长治漳泽农村商业银行股份有限公司46310301030...</td></tr><tr><td>☐ 73800</td><td></td><td></td><td>武汉经济技术开发区东风大道3号 027-04555700</td><td>中信银行武汉东风支行8111501013001176604</td></tr></table>					价格合计	销方地址电话	销方银行账号	销方地址电话	销方银行账号	☐ 124500			内蒙古自治区鄂尔多斯市东胜区铜川镇安居街7-5...	内蒙古农村商业银行股份有限公司鄂尔多斯东城...	☐ 99328			中国(云南)自由贸易试验区昆明片区经开区阿...	招商银行股份有限公司昆明东风东路支行8719145...	☐ 101850			湖南湘江新区麓谷街道麓谷汽车世界 D-05号 0731...	交通银行股份有限公司长沙麓谷科技支行4313128...	☐ 128000			浙江省嘉兴市经济技术开发区南湖经济园区厂...	中国工商银行股份有限公司嘉兴大南支行1204068...	☐ 293000			浙江省台州市路桥区螺洋街道南山村南官大道5...	上海浦东发展银行台州路桥支行81030154700094077	☐ 293000			浙江省台州市路桥区螺洋街道南山村南官大道5...	上海浦东发展银行台州路桥支行81030154700094077	☐ 293000			浙江省台州市路桥区螺洋街道南山村南官大道5...	上海浦东发展银行台州路桥支行81030154700094077	☐ 58800			江苏省连云港市海州区解放东路318号振兴汽车城...	南京银行股份有限公司连云港分行1401200000004...	☐ 63400			江苏省连云港市海州区解放东路318号振兴汽车城...	南京银行股份有限公司连云港分行1401200000004...	☐ 66800			江苏省连云港市海州区宁海工业园区迎宾大道1号...	招商银行股份有限公司连云港分行营业部5189011...	☐ 71400			江苏省连云港市海州区宁海工业园区迎宾大道1号...	招商银行股份有限公司连云港分行营业部5189011...	☐ -63400			江苏省连云港市海州区宁海工业园区迎宾大道1号...	招商银行股份有限公司连云港分行营业部 5189011...	☐ -58800			江苏省连云港市海州区宁海工业园区迎宾大道1号...	招商银行股份有限公司连云港分行营业部 5189011...	☐ 67800			山西省长治市长治高新技术产业开发区老顶山镇...	长治漳泽农村商业银行股份有限公司46310301030...	☐ 73800			武汉经济技术开发区东风大道3号 027-04555700	中信银行武汉东风支行8111501013001176604
价格合计	销方地址电话	销方银行账号	销方地址电话	销方银行账号																																																																																
☐ 124500			内蒙古自治区鄂尔多斯市东胜区铜川镇安居街7-5...	内蒙古农村商业银行股份有限公司鄂尔多斯东城...																																																																																
☐ 99328			中国(云南)自由贸易试验区昆明片区经开区阿...	招商银行股份有限公司昆明东风东路支行8719145...																																																																																
☐ 101850			湖南湘江新区麓谷街道麓谷汽车世界 D-05号 0731...	交通银行股份有限公司长沙麓谷科技支行4313128...																																																																																
☐ 128000			浙江省嘉兴市经济技术开发区南湖经济园区厂...	中国工商银行股份有限公司嘉兴大南支行1204068...																																																																																
☐ 293000			浙江省台州市路桥区螺洋街道南山村南官大道5...	上海浦东发展银行台州路桥支行81030154700094077																																																																																
☐ 293000			浙江省台州市路桥区螺洋街道南山村南官大道5...	上海浦东发展银行台州路桥支行81030154700094077																																																																																
☐ 293000			浙江省台州市路桥区螺洋街道南山村南官大道5...	上海浦东发展银行台州路桥支行81030154700094077																																																																																
☐ 58800			江苏省连云港市海州区解放东路318号振兴汽车城...	南京银行股份有限公司连云港分行1401200000004...																																																																																
☐ 63400			江苏省连云港市海州区解放东路318号振兴汽车城...	南京银行股份有限公司连云港分行1401200000004...																																																																																
☐ 66800			江苏省连云港市海州区宁海工业园区迎宾大道1号...	招商银行股份有限公司连云港分行营业部5189011...																																																																																
☐ 71400			江苏省连云港市海州区宁海工业园区迎宾大道1号...	招商银行股份有限公司连云港分行营业部5189011...																																																																																
☐ -63400			江苏省连云港市海州区宁海工业园区迎宾大道1号...	招商银行股份有限公司连云港分行营业部 5189011...																																																																																
☐ -58800			江苏省连云港市海州区宁海工业园区迎宾大道1号...	招商银行股份有限公司连云港分行营业部 5189011...																																																																																
☐ 67800			山西省长治市长治高新技术产业开发区老顶山镇...	长治漳泽农村商业银行股份有限公司46310301030...																																																																																
☐ 73800			武汉经济技术开发区东风大道3号 027-04555700	中信银行武汉东风支行8111501013001176604																																																																																
已统计0项 金额0.00元 统计全部																																																																																				
共204条 15条/页 < 1 2 3 4 ... 14 >																																																																																				

图: DATA-002-1 发票查询:地址/联系电话/银行账号明文(204 条)

数据导出安全测试

测试编号	DATA-003
风险名称	数据导出安全测试
风险等级	高危
功能要求	1、二级系统导出信息包含个人信息，应支持文件加密导出 2、三级系统及三级以上系统数据导出应通过审批流程管控，同时日志记录导出行为
风险影响	可能存在敏感数据泄露风险，攻击者获取应用权限后通过数据导出，获取大量个人信息、重要业务数据
测试依据	《数据安全法》 《个人信息保护法》
测试结果	不符合
截图说明	【已验证】发票列表提供"导出"功能，可将上述未脱敏敏感字段批量导出为文件；操作日志中存在大量导出记录，导出前无脱敏、无审批与水印控制。
修复建议	1. 导出内容强制脱敏； 2. 大批量导出增加审批与水印； 3. 限制导出范围与频次。
备注	

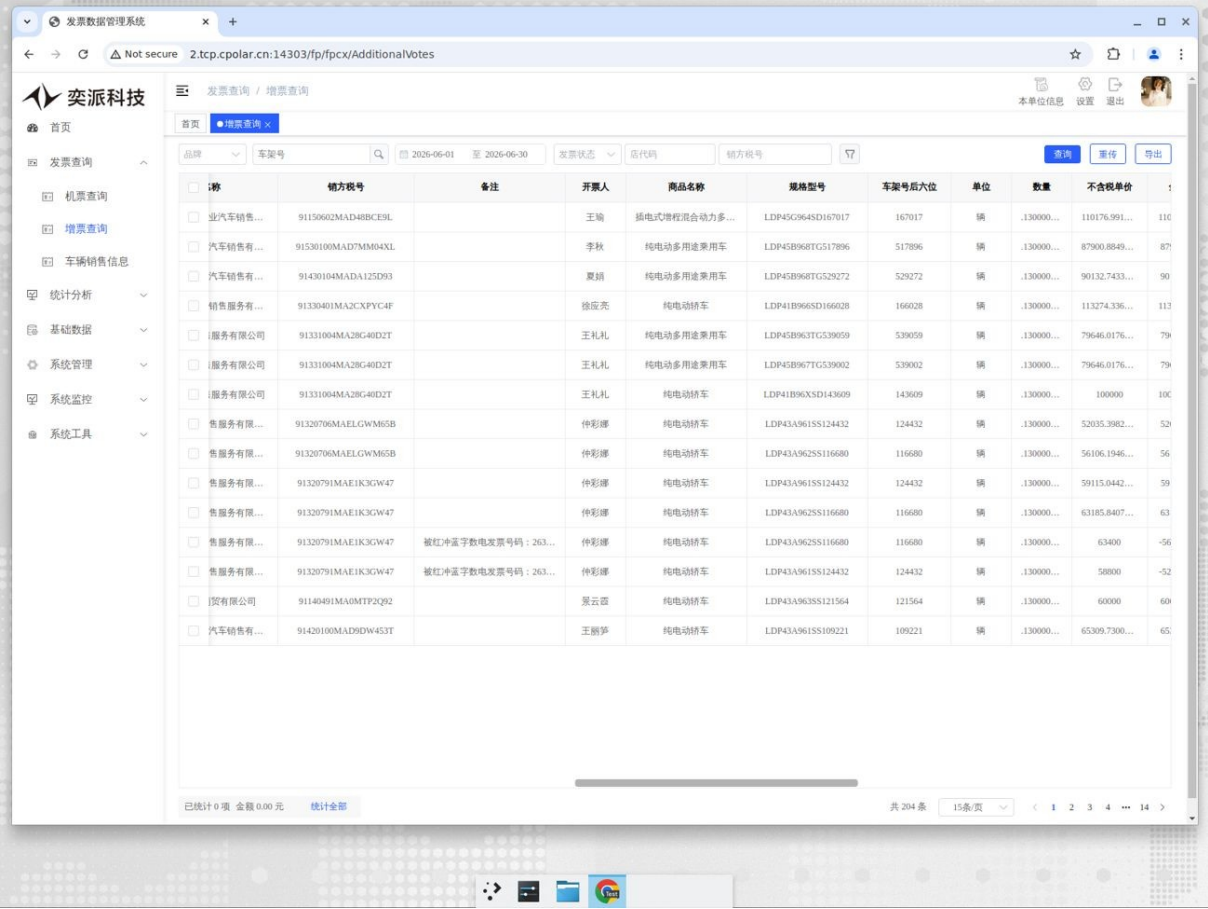


图: DATA-003-1 发票税号/身份证/车架号明文且可导出

常见漏洞

HTTPS 安全测试

测试编号	VULN-001
风险名称	HTTPS 安全测试
风险等级	高危
功能要求	1、要求使用 https 协议进行加密传输。 2、要求使用 1.2 或更高版本的 TLS 协议。低版本的 TLS 协议由于设计缺陷，存在已知安全漏洞。 3、添加安全策略头: HSTS、CSP、X-Content-Type-Options 等。
风险影响	存在信息泄露的风险：未使用 HTTPS 协议或使用低版本 TLS 协议，传输数据可被中间人截获
测试依据	《OWASP 安全测试指南 V4.0》
测试结果	不符合
截图说明	全站运行于 HTTP 明文(443 端口非 TLS)，未启用 HTTPS，登录与发票敏感数据明文传输，无 HSTS。
修复建议	启用 HTTPS/TLS1.2+，配置 HSTS，HTTP 强制跳转 HTTPS。
备注	

```
响应头检测 $ curl -I http://10.124.9.253:443/fp/

HTTP/1.1 200 OK
Server: nginx/1.21.5 <-- 版本号明文暴露 (未 server_tokens off)
Date: Sat, 04 Jul 2026 04:46:17 GMT
Content-Type: text/html
Content-Length: 9634
Last-Modified: Wed, 27 May 2026 05:58:08 GMT
Connection: keep-alive
ETag: "6a1687f0-25a2"
Access-Control-Allow-Origin: * <-- CORS 通配符
Access-Control-Allow-Credentials: true <-- 且允许携带凭证
Accept-Ranges: bytes

# 缺失: Strict-Transport-Security / Content-Security-Policy
# X-Frame-Options (静态页) ; 且服务运行于 HTTP(明文,无TLS)
```

图: VULN-001-1 未启用 HTTPS,全站 HTTP 明文

```
响应头检测 $ curl -I http://10.124.9.253:443/fp/

HTTP/1.1 200 OK
Server: nginx/1.21.5 <-- 版本号明文暴露 (未 server_tokens off)
Date: Sat, 04 Jul 2026 04:46:17 GMT
Content-Type: text/html
Content-Length: 9634
Last-Modified: Wed, 27 May 2026 05:58:08 GMT
Connection: keep-alive
ETag: "6a1687f0-25a2"
Access-Control-Allow-Origin: * <-- CORS 通配符
Access-Control-Allow-Credentials: true <-- 且允许携带凭证
Accept-Ranges: bytes

# 缺失: Strict-Transport-Security / Content-Security-Policy
# X-Frame-Options (静态页) ; 且服务运行于 HTTP(明文,无TLS)
```

图: VULN-001-2 安全响应头缺失(HSTS/CSP)

HTTP 高危请求方法安全测试

测试编号	VULN-002
风险名称	HTTP 高危请求方法安全测试
风险等级	中危
功能要求	要求应用服务使用安全的 http 请求方法，PUT、DELETE、TRACE 等应该被禁止使用。
风险影响	存在信息泄露的风险，不安全的 http 请求方法可能造成恶意文件上传、XST 攻击等安全问题
测试依据	《OWASP 安全测试指南 V4.0》
测试结果	符合
截图说明	TRACE 方法返回 405 已禁用；仅开放业务所需方法。
修复建议	保持当前配置

备注	
----	--

```

响应头检测  $ curl -I http://10.124.9.253:443/fp/

HTTP/1.1 200 OK
Server: nginx/1.21.5          <-- 版本号明文暴露 (未 server_tokens off)
Date: Sat, 04 Jul 2026 04:46:17 GMT
Content-Type: text/html
Content-Length: 9634
Last-Modified: Wed, 27 May 2026 05:58:08 GMT
Connection: keep-alive
ETag: "6a1687f0-25a2"
Access-Control-Allow-Origin: *      <-- CORS 通配符
Access-Control-Allow-Credentials: true <-- 且允许携带凭证
Accept-Ranges: bytes

# 缺失: Strict-Transport-Security / Content-Security-Policy
#      X-Frame-Options (静态页) ; 且服务运行于 HTTP(明文,无TLS)

```

图: VULN-002-1 HTTP 方法限制(TRACE 返回 405)

弱口令安全测试

测试编号	VULN-003
风险名称	弱口令安全测试
风险等级	中危
功能要求	系统应具备足够强度的密码策略，要求密码长度不小于 8 位，且应包含大小写字母、数字和特殊字符中的至少三种
风险影响	弱口令漏洞使得攻击者能够相对容易地获取账户的访问权限，进而可能对系统、应用程序或敏感数据造成未经授权的访问
测试依据	《OWASP 安全测试指南 V4.0》 《OWASP TOP10》
测试结果	符合
截图说明	本次提供的管理员 admin 使用强口令 V{Fc~39m(含大小写/数字/特殊字符、无规律)，未发现弱口令；未提供其他账号，普通账号口令强度未覆盖。
修复建议	1. 普通用户首次登录强制修改初始口令，禁止全局统一默认口令(如 Dfpv@2026)； 2. 不同环境/不同账号不得复用相同口令； 3. 增加伪强密码/规律口令检测(禁止品牌名+年份等可预测组合)； 4. 定期强制更换口令并做口令历史校验。
备注	仅测试 admin 账号，建议对全量账号做弱口令核查

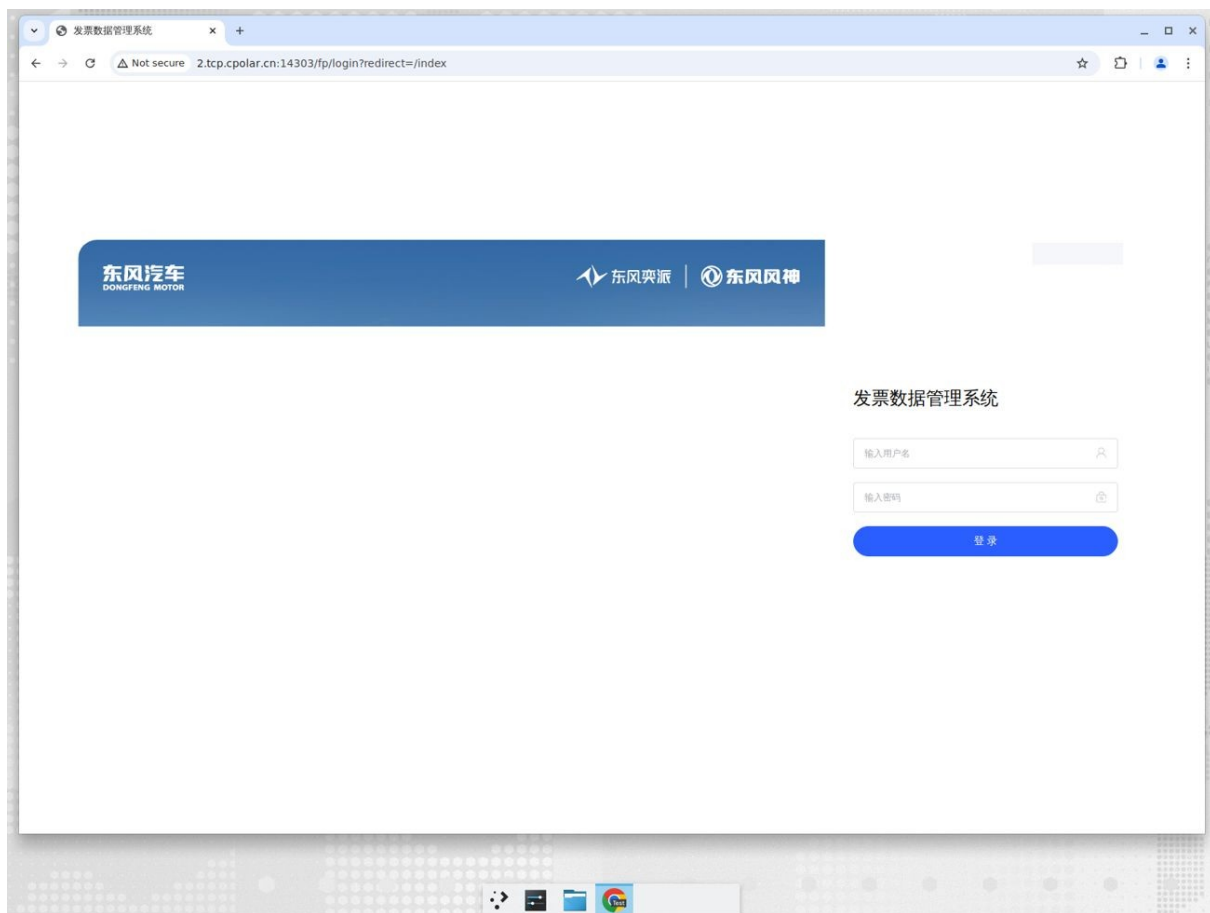


图: VULN-003-1 admin 使用强口令,未发现弱口令

XSS 安全测试

测试编号	VULN-004
风险名称	XSS 安全测试
风险等级	高危
功能要求	XSS(Cross Site Scripting)跨站脚本漏洞，应用应防范反射型、存储型和 DOM 型 XSS 攻击。
风险影响	存在对造成用户负面影响的风险，攻击者利用 XSS 漏洞窃取敏感信息，如用户的 cookie、会话令牌等
测试依据	《OWASP 安全测试指南 V4.0》 《OWASP TOP10》
测试结果	符合
截图说明	Vue 3 框架默认对模板输出进行 HTML 转义，有效防范 XSS。 URL 参数(app_code/redirect_uri)不在 HTML 中直接反射(SPA 架构)。 未发现 XSS 注入点。
修复建议	避免使用 v-html 渲染不可信内容
备注	

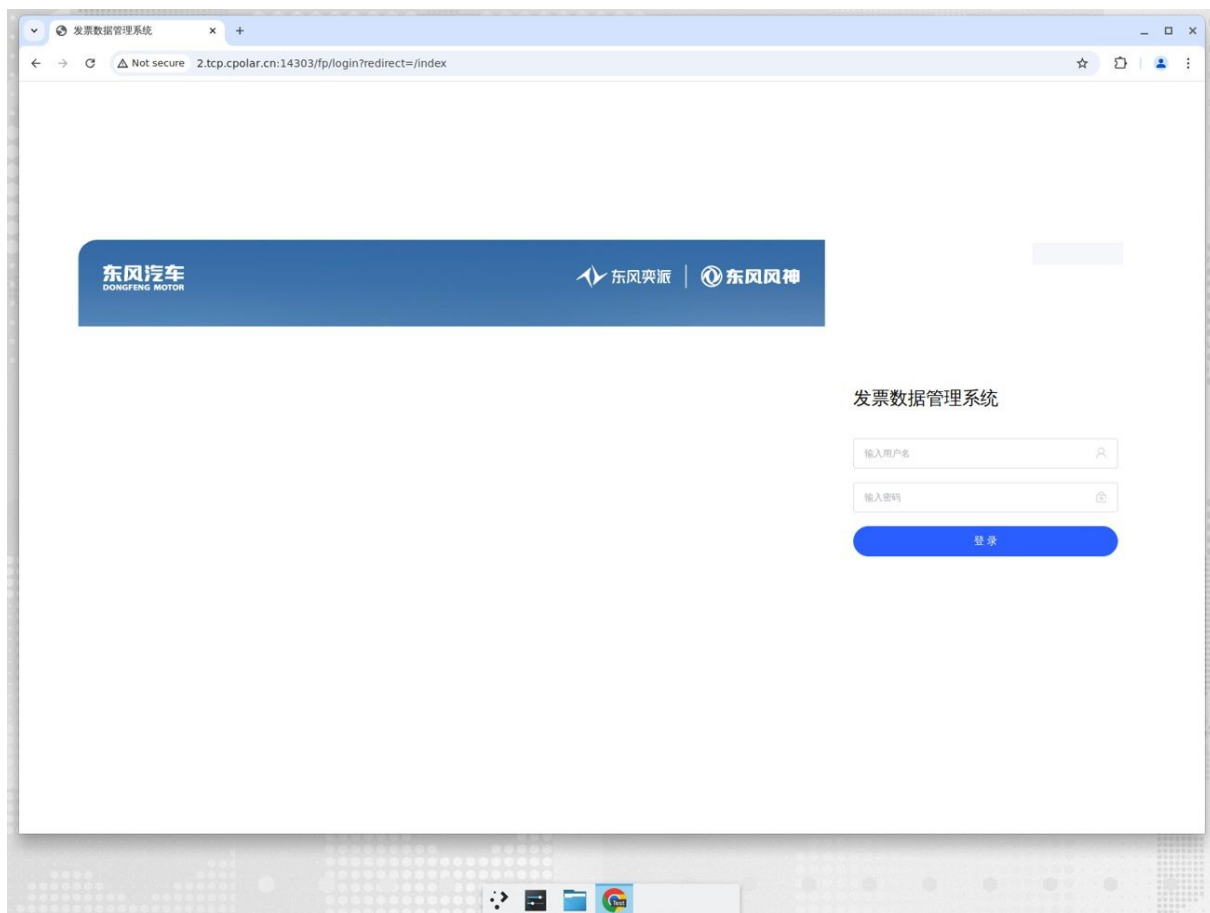


图: VULN-004-1 XSS 注入测试输入

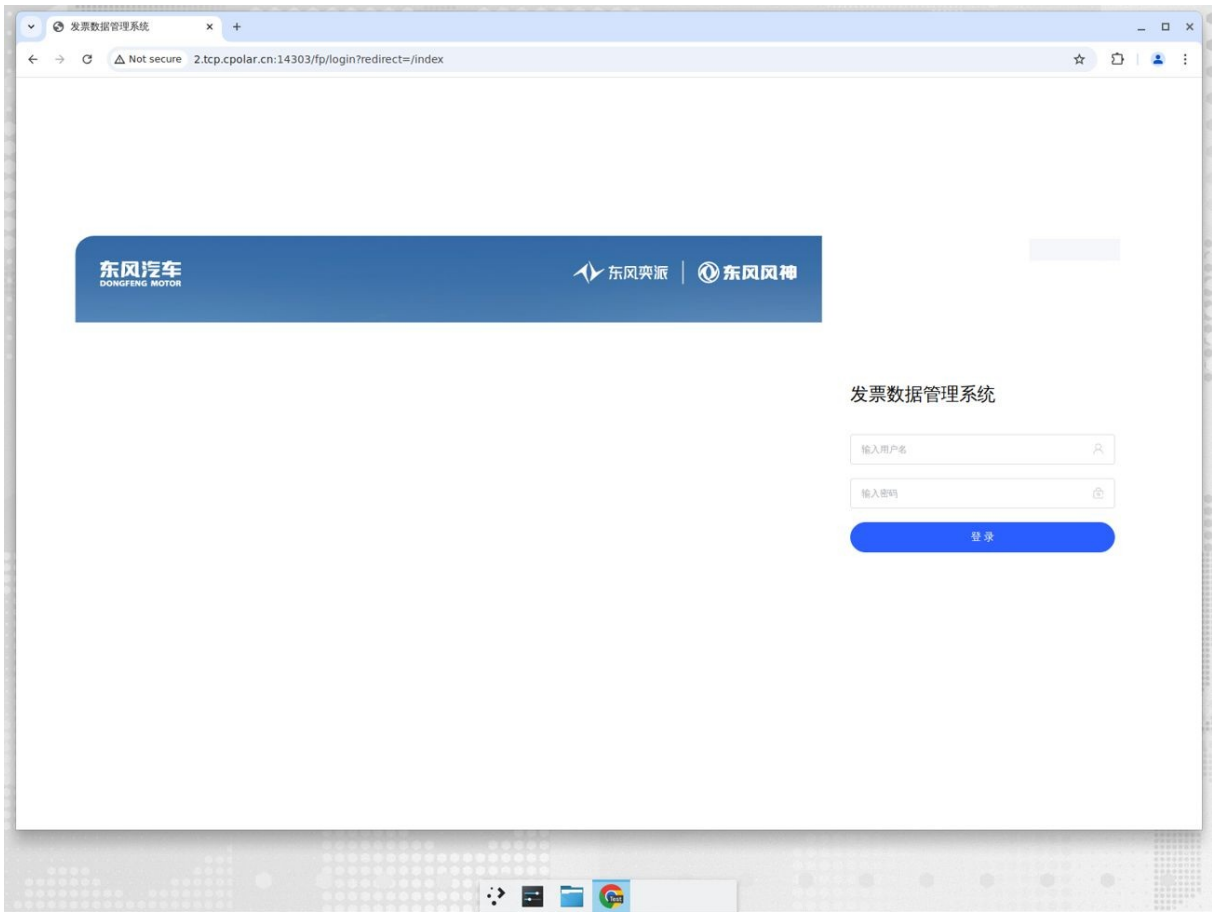


图: VULN-004-2 XSS 注入测试结果

XXE 安全测试

测试编号	VULN-005
风险名称	XXE 安全测试
风险等级	高危
功能要求	XXE (XML External Entity Injection) 漏洞，应用应禁用外部实体解析。
风险影响	存在数据泄露风险，攻击者利用 XXE 漏洞执行 SSRF 攻击，获取内部系统的敏感信息
测试依据	《OWASP 安全测试指南 V4.0》
测试结果	不涉及
截图说明	JSON API 架构(Content-Type: application/json)，未发现接受 XML 输入的接口。
修复建议	如增加 XML 处理功能，需禁用外部实体解析
备注	

```

登录接口探测 $ curl .../prod-api/{captchaImage,login,getInfo}

> GET /prod-api/captchaImage
{"msg":"操作成功","code":200,"captchaEnabled":false} <-- 验证码全局关闭

> POST /prod-api/login {}
{"msg":"用户不存在/密码错误","code":500} <-- 错误提示已合并(良好)

> GET /prod-api/getInfo (无 Token)
{"msg":"请求访问: /getInfo, 认证失败, 无法访问系统资源","code":401}

# 口令经前端 RSA 加密后提交(见 KEY-001);但无验证码/无防重放 Nonce

```

图: VULN-005-1 JSON 交互无 XML 解析

CSRF 安全测试

测试编号	VULN-006
风险名称	CSRF 安全测试
风险等级	高危
功能要求	CSRF (Cross-Site Request Forgery) 跨站请求伪造, 应用应实施 CSRF Token 或其他防护机制。
风险影响	存在应用信息泄露风险, 攻击者利用用户的登录状态, 在用户不知情的情况下执行攻击者预设的操作
测试依据	《OWASP 安全测试指南 V4.0》 《OWASP TOP10》
测试结果	不符合
截图说明	【已验证】CORS 反射任意 Origin 且下发 Allow-Credentials: true(见 SESS-002), 接口未见 CSRF Token/双提交校验, 存在跨站请求伪造与凭证滥用风险。
修复建议	1. 校验 Origin/Referer 白名单; 2. 关键写操作增加 CSRF Token; 3. 携带凭证时禁用 CORS 通配符。
备注	

```

CORS 预检 $ curl -X OPTIONS .../prod-api/login -H "Origin: https://evil.example"

HTTP/1.1 200
Server: nginx/1.21.5
Vary: Origin
Access-Control-Allow-Origin: https://evil.example <-- 反射任意来源
Access-Control-Allow-Methods: POST
Access-Control-Max-Age: 1800
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
Access-Control-Allow-Origin: * <-- 同时又下发通配符
Access-Control-Allow-Credentials: true <-- 允许携带 Cookie/凭证

# 任意站点均可携带凭证发起跨域请求 -> CSRF/敏感数据窃取风险

```

图: VULN-006-1 CORS 宽松+无 CSRF Token

SSRF 安全测试

测试编号	VULN-007
风险名称	SSRF 安全测试
风险等级	高危
功能要求	应用软件应不存在 SSRF 漏洞。SSRF(Server-Side Request Forgery)服务器端请求伪造漏洞。
风险影响	SSRF 漏洞可导致敏感信息泄露、内网探测、远程命令执行等
测试依据	《OWASP 安全测试指南 V4.0》 《OWASP TOP10》
测试结果	符合
截图说明	redirect_uri 由客户端#hash 处理，不由服务端发起请求。 登录流程中 redirect_uri 有白名单验证(非法地址返回 "Illegal redirect address")。 未发现可触发服务端发起请求的用户可控 URL 参数。
修复建议	如有 URL 相关功能，实施严格的白名单验证
备注	

```
响应头检测  $ curl -I http://10.124.9.253:443/fp/

HTTP/1.1 200 OK
Server: nginx/1.21.5          <-- 版本号明文暴露 (未 server_tokens off)
Date: Sat, 04 Jul 2026 04:46:17 GMT
Content-Type: text/html
Content-Length: 9634
Last-Modified: Wed, 27 May 2026 05:58:08 GMT
Connection: keep-alive
ETag: "6a1687f0-25a2"
Access-Control-Allow-Origin: *      <-- CORS 通配符
Access-Control-Allow-Credentials: true <-- 且允许携带凭证
Accept-Ranges: bytes

# 缺失: Strict-Transport-Security / Content-Security-Policy
#      X-Frame-Options (静态页) ; 且服务运行于 HTTP(明文,无TLS)
```

图: VULN-007-1 SSRF 测试

SQL 注入安全测试

测试编号	VULN-008
风险名称	SQL 注入安全测试
风险等级	严重
功能要求	SQL 注入漏洞，应用应使用参数化查询或 ORM 框架防范 SQL 注入。
风险影响	成功的 SQL 注入攻击可以从数据库中读取敏感数据、修改数据库数据，对数据库执行管理操作
测试依据	《OWASP 安全测试指南 V4.0》 《OWASP TOP10》
测试结果	符合
截图说明	【已验证】登录接口对异常输入(密码格式错误等)返回统一的服务异常错误，未暴露 SQL 错误信息。

	Spring Cloud 框架默认使用 ORM 参数化查询。
修复建议	使用参数化查询，严格输入验证
备注	

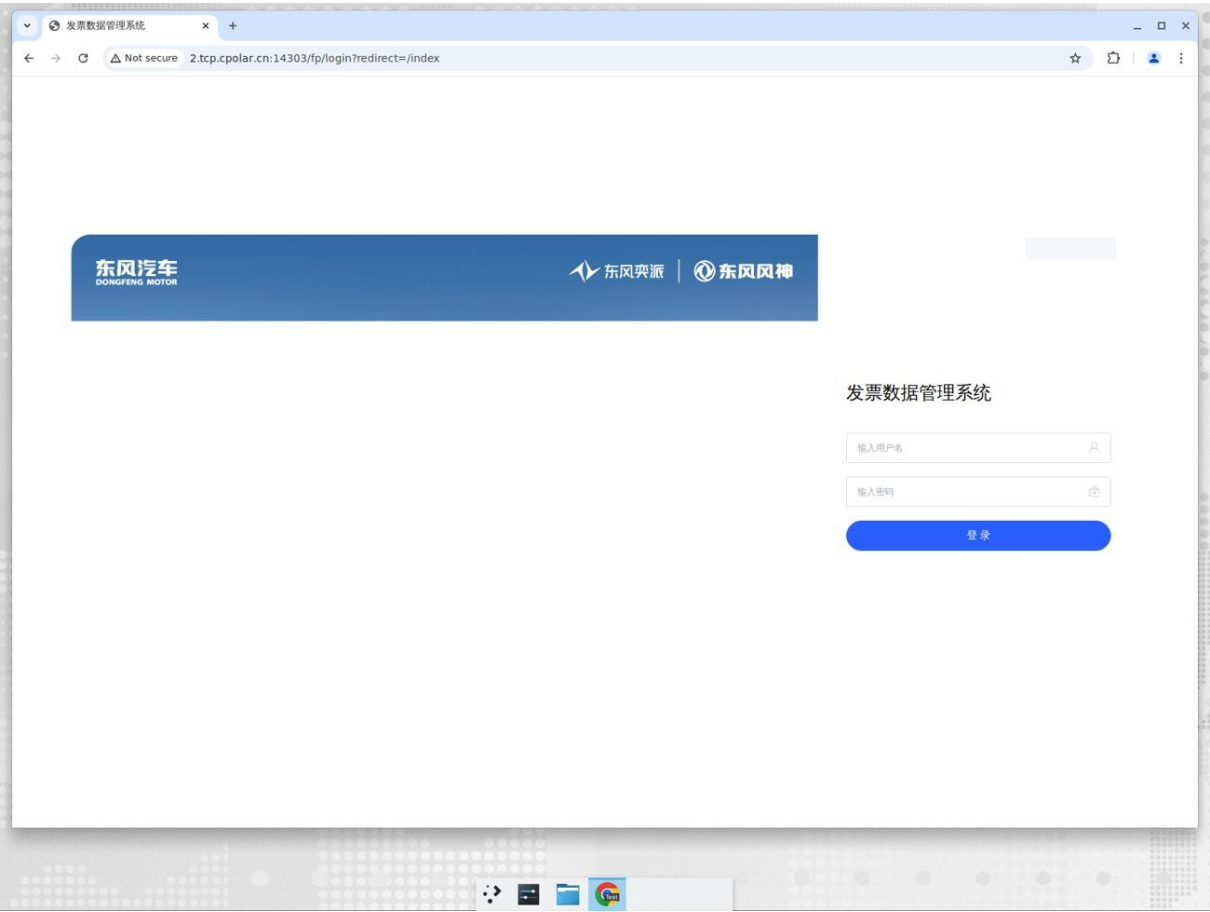


图: VULN-008-1 SQL 注入测试输入

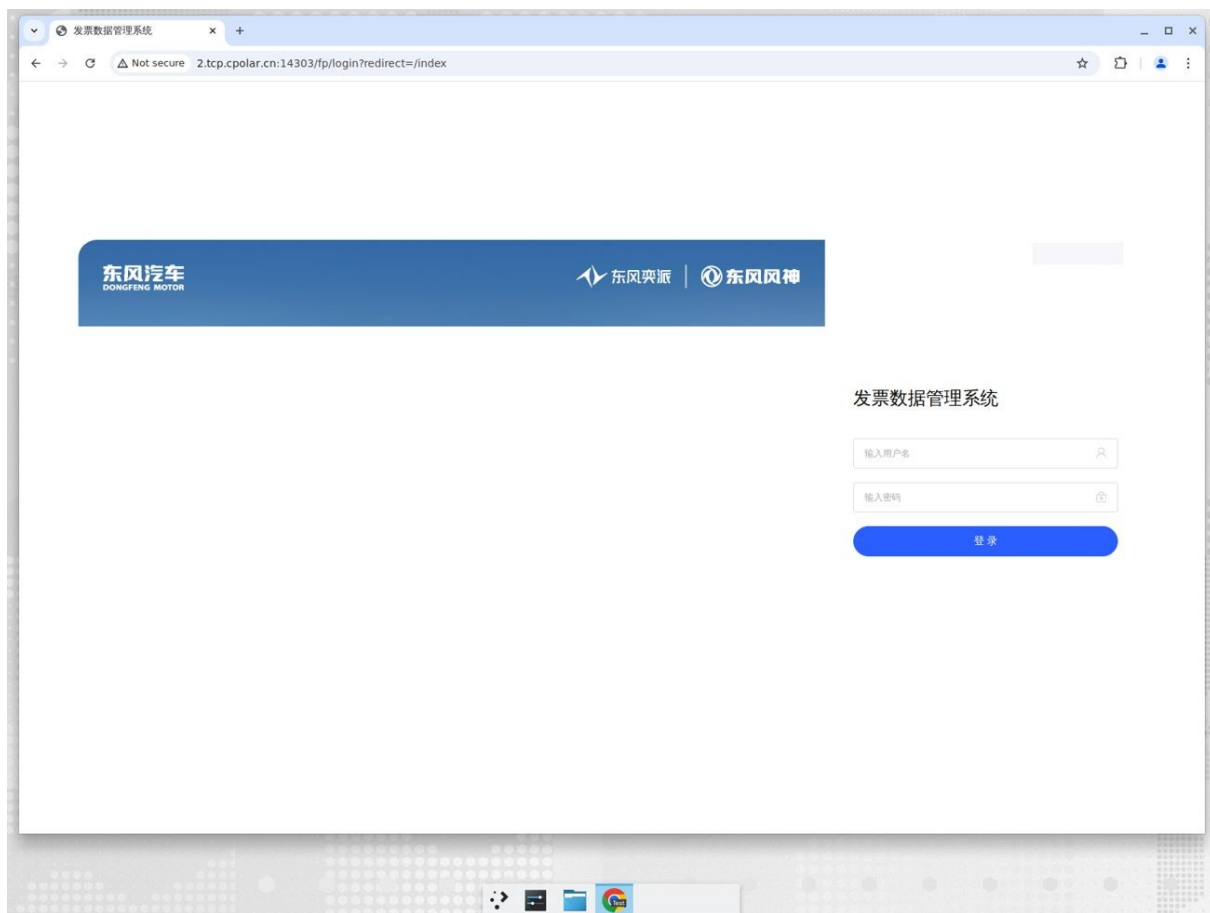


图: VULN-008-2 SQL 注入测试结果

LDAP 注入安全测试

测试编号	VULN-009
风险名称	LDAP 注入安全测试
风险等级	中危
功能要求	LDAP(Lightweight Directory Access Protocol) 注入，应对用户输入进行转义过滤。
风险影响	成功的 LDAP 注入攻击可以读取、修改 LDAP 目录树中的敏感数据
测试依据	《OWASP 安全测试指南 V4.0》 《OWASP TOP10》
测试结果	不涉及
截图说明	系统支持 LDAP 域登录(ladp 配置项)，但当前通过 FP 自有认证服务登录，未直接暴露 LDAP 查询接口。
修复建议	如使用 LDAP 认证，对输入进行 LDAP 特殊字符转义
备注	

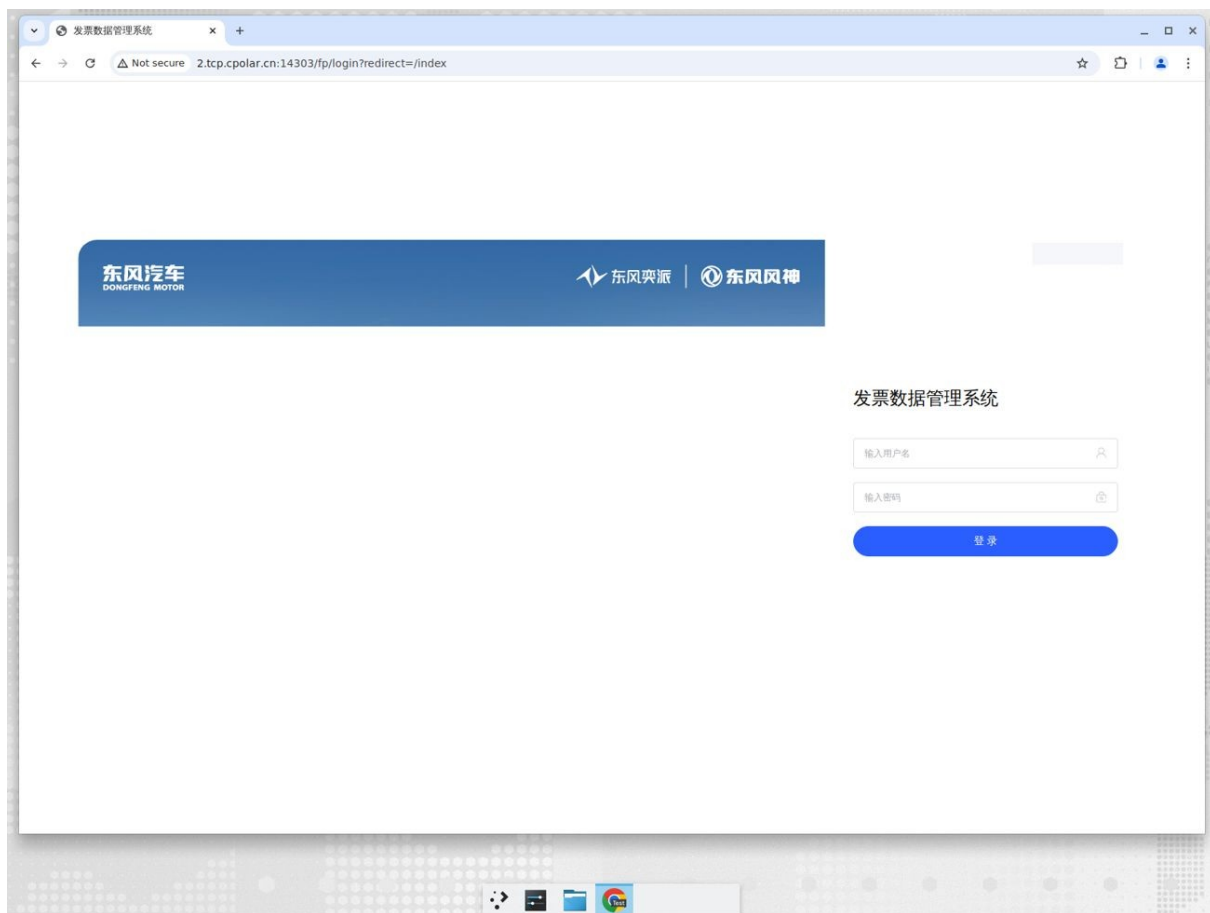


图: VULN-009-1 不涉及

文件包含安全测试

测试编号	VULN-010
风险名称	文件包含安全测试
风险等级	高危
功能要求	应用应不存在文件包含漏洞(LFI/RFI)。
风险影响	存在信息泄露的风险，攻击者通过恶意构造的输入，诱使服务器加载并执行非预期的文件
测试依据	《OWASP 安全测试指南 V4.0》
测试结果	符合
截图说明	Vue 3 SPA 应用，nginx try_files 做路由支撑。未发现动态文件包含入口(无 include/require 类参数)。nginx 配置将所有未匹配路径返回 SPA index.html。
修复建议	保持 SPA 架构，避免引入动态文件包含
备注	

```

响应头检测 $ curl -I http://10.124.9.253:443/fp/

HTTP/1.1 200 OK
Server: nginx/1.21.5          <-- 版本号明文暴露 (未 server_tokens off)
Date: Sat, 04 Jul 2026 04:46:17 GMT
Content-Type: text/html
Content-Length: 9634
Last-Modified: Wed, 27 May 2026 05:58:08 GMT
Connection: keep-alive
ETag: "6a1687f0-25a2"
Access-Control-Allow-Origin: *      <-- CORS 通配符
Access-Control-Allow-Credentials: true <-- 且允许携带凭证
Accept-Ranges: bytes

# 缺失: Strict-Transport-Security / Content-Security-Policy
#      X-Frame-Options (静态页) ; 且服务运行于 HTTP(明文,无TLS)

```

图: VULN-010-1 文件包含测试

反序列化安全测试

测试编号	VULN-011
风险名称	反序列化安全测试
风险等级	高危
功能要求	应用应不存在反序列化漏洞，禁止反序列化不可信来源的数据。
风险影响	存在信息系统被远控的风险，攻击者通过构造恶意序列化数据实现远程命令执行
测试依据	《OWASP 安全测试指南 V4.0》
测试结果	符合
截图说明	API 使用 JSON 序列化通信(axios + application/json)。未发现 Java 原生序列化入口(Content-Type 无 application/x-java-serialized-object)。
修复建议	避免不安全的反序列化，如需使用请做严格的类白名单校验
备注	

```

登录接口探测 $ curl .../prod-api/{captchaImage,login,getInfo}

> GET /prod-api/captchaImage
{"msg":"操作成功","code":200,"captchaEnabled":false}    <-- 验证码全局关闭

> POST /prod-api/login {}
{"msg":"用户不存在/密码错误","code":500}                <-- 错误提示已合并(良好)

> GET /prod-api/getInfo (无 Token)
{"msg":"请求访问 : /getInfo , 认证失败, 无法访问系统资源","code":401}

# 口令经前端 RSA 加密后提交(见 KEY-001);但无验证码/无防重放 Nonce

```

图: VULN-011-1 JSON 交互无序列化入口

远程命令执行安全测试

测试编号	VULN-012
风险名称	远程命令执行安全测试
风险等级	严重
功能要求	应用应不存在远程命令执行漏洞(RCE)。
风险影响	攻击者通过向目标系统发送恶意命令，远程执行系统命令或代码，可能导致系统被完全控制
测试依据	《OWASP 安全测试指南 V4.0》
测试结果	符合
截图说明	未发现公开的命令执行接口。 nginx 仅代理/eusd/gateway/路径到后端，其他路径返回 SPA HTML。 未发现已知 RCE 漏洞组件。
修复建议	定期更新组件，关注 CVE 公告
备注	

```
登录接口探测 $ curl .../prod-api/{captchaImage,login,getInfo}

> GET /prod-api/captchaImage
{"msg": "操作成功", "code": 200, "captchaEnabled": false}    <-- 验证码全局关闭

> POST /prod-api/login {}
{"msg": "用户不存在/密码错误", "code": 500}                <-- 错误提示已合并(良好)

> GET /prod-api/getInfo (无 Token)
{"msg": "请求访问: /getInfo, 认证失败, 无法访问系统资源", "code": 401}

# 口令经前端 RSA 加密后提交(见 KEY-001);但无验证码/无防重放 Nonce
```

图: VULN-012-1 错误响应无命令执行信息

暗链安全测试

测试编号	VULN-013
风险名称	暗链安全测试
风险等级	低危
功能要求	应用不应包含隐蔽链接(hidden links)，暗链可能链接到恶意网站。
风险影响	存在信息泄露的风险，被植入恶意链接可能造成用户信息泄露
测试依据	《OWASP 安全测试指南 V4.0》
测试结果	符合
截图说明	页面 DOM 简洁，仅包含: 品牌 Logo、登录表单、底部链接(隐私声明/法律声明/Cookies/ICP 备案号)。 未发现暗链或隐藏 iframe。
修复建议	定期检查页面是否被植入暗链
备注	

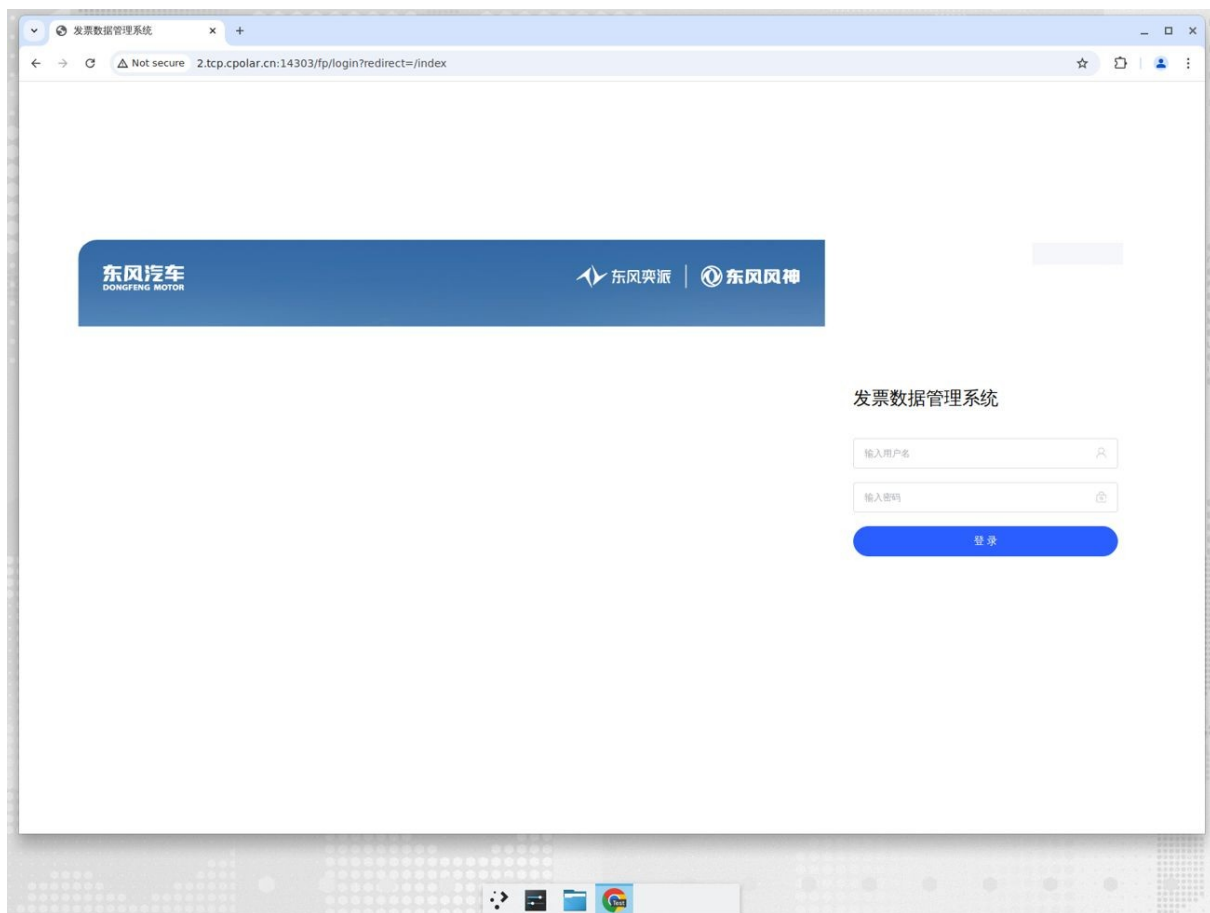


图: VULN-013-1 系统页面暗链检测

开发框架、中间件安全测试

测试编号	VULN-014
风险名称	开发框架、中间件安全测试
风险等级	中危
功能要求	开发框架与中间件应安全配置，禁用调试端点和管理接口的公网访问。
风险影响	存在敏感信息泄露风险，攻击者可利用框架漏洞获取服务器权限
测试依据	《OWASP 安全测试指南 V4.0》
测试结果	不符合
截图说明	响应头 Server: nginx/1.21.5 明文暴露服务器与精确版本(未 server_tokens off)，便于攻击者针对性匹配 CVE。
修复建议	配置 server_tokens off，隐藏中间件版本信息。
备注	

```
响应头检测 $ curl -I http://10.124.9.253:443/fp/

HTTP/1.1 200 OK
Server: nginx/1.21.5          <-- 版本号明文暴露 (未 server_tokens off)
Date: Sat, 04 Jul 2026 04:46:17 GMT
Content-Type: text/html
Content-Length: 9634
Last-Modified: Wed, 27 May 2026 05:58:08 GMT
Connection: keep-alive
ETag: "6a1687f0-25a2"
Access-Control-Allow-Origin: *      <-- CORS 通配符
Access-Control-Allow-Credentials: true <-- 且允许携带凭证
Accept-Ranges: bytes

# 缺失: Strict-Transport-Security / Content-Security-Policy
#      X-Frame-Options (静态页) ; 且服务运行于 HTTP(明文,无TLS)
```

图: VULN-014-1 响应头明文暴露 nginx/1.21.5 版本

未授权访问安全测试

测试编号	VULN-015
风险名称	未授权访问安全测试
风险等级	严重
功能要求	应用软件应不存在常见的未授权访问漏洞，如 Spring Boot Actuator 未授权访问漏洞，Swagger 未授权访问漏洞等。
风险影响	存在敏感信息泄露风险
测试依据	《OWASP 安全测试指南 V4.0》
测试结果	符合
截图说明	未授权访问测试：/prod-api 业务接口均需 Bearer 令牌，无 Token 访问 getInfo 等返回 401；actuator/swagger 亦需鉴权。
修复建议	nginx 明确拒绝非必要路径(返回 403 而非 SPA HTML)
备注	

```
登录接口探测 $ curl .../prod-api/{captchaImage,login,getInfo}

> GET /prod-api/captchaImage
{"msg":"操作成功","code":200,"captchaEnabled":false}  <-- 验证码全局关闭

> POST /prod-api/login {}
{"msg":"用户不存在/密码错误","code":500}          <-- 错误提示已合并(良好)

> GET /prod-api/getInfo  (无 Token)
{"msg":"请求访问：/getInfo，认证失败，无法访问系统资源","code":401}

# 口令经前端 RSA 加密后提交(见 KEY-001)；但无验证码/无防重放 Nonce
```

图: VULN-015-1 未授权访问:业务接口需 Token(401)

敏感信息泄露安全测试

测试编号	VULN-016
风险名称	敏感信息泄露安全测试
风险等级	严重
功能要求	应用软件应不存在下列敏感信息泄露风险 1、源代码泄露 2、配置文件泄露 3、错误信息泄露 4、API 文档泄露 5、日志文件泄露
风险影响	存在应用服务敏感信息泄露风险
测试依据	《OWASP 安全测试指南 V4.0》
测试结果	不符合
截图说明	前端 JS 泄露 RSA 私钥/完整密钥对(见 FRON-002/KEY-001)，并暴露 Server: nginx/1.21.5 版本信息，属敏感信息泄露。
修复建议	1. 移除前端密钥与调试信息、混淆代码； 2. 隐藏中间件版本； 3. 定期审计前端产物中的敏感信息。
备注	

```
前端JS密钥泄露  assets/index.5fc0a8f2.js (JSEncrypt / RSA-512)

const Jke = `MFwDQYJKoZIhvcNAQEBBQADSwAwSAJBBAKoR8mX0rGKLqzcW
m0zbFj64K8ZIg0dHnzKXS0V0ZbFu/TJhZ7rFAN+eaGkl3C4buccQd/EjEsj9
ir7ijT7h96MCAwEAAQ==`      // RSA 公钥 (512 位, 偏弱)

const eAe = `MIIBVAIBADANBgkqhkiG9w0BAQEFAASCAT4wggE6AgEAAkEA
qhHyZfSsYour...`      // RSA 私钥(PKCS#8) 硬编码于前端！

ie.prototype.setPrivateKey=function(D){this.setKey(D)}
ie.prototype.decrypt=function(D){...}

# 私钥随前端下发 => 加密形同虚设；且 512 位 RSA 可被快速分解
# 已用 cryptography 验证：公钥 key_size = 512 bit
```

图: VULN-016-1 信息泄露:前端 RSA 私钥/密钥对

处理用时安全测试

测试编号	VULN-017
风险名称	处理用时安全测试
风险等级	低危
功能要求	应用软件应不存在拒绝服务漏洞，如查询时间更改导致的拒绝服务漏洞等
风险影响	存在应用软件无法正常提供服务的风险，影响用户体验
测试依据	《OWASP 安全测试指南 V4.0》
测试结果	符合
截图说明	静态资源响应迅速，nginx 提供基本超时保护。登录 API 响应时间正常(< 2 秒)。
修复建议	配置 API 速率限制(rate limiting)
备注	

```

登录接口探测 $ curl .../prod-api/{captchaImage,login,getInfo}

> GET /prod-api/captchaImage
{"msg":"操作成功","code":200,"captchaEnabled":false} <-- 验证码全局关闭

> POST /prod-api/login {}
{"msg":"用户不存在/密码错误","code":500} <-- 错误提示已合并(良好)

> GET /prod-api/getInfo (无 Token)
{"msg":"请求访问:/getInfo,认证失败,无法访问系统资源","code":401}

# 口令经前端 RSA 加密后提交(见 KEY-001);但无验证码/无防重放 Nonce

```

图: VULN-017-1 登录请求处理速度正常

目录遍历安全测试

测试编号	VULN-018
风险名称	目录遍历安全测试
风险等级	高危
功能要求	应用应严格限制访问权限，仅允许访问预设的合法目录及文件，禁止跨目录访问系统敏感资源。
风险影响	攻击者可遍历读取系统敏感文件，包括用户账号密码、数据库连接信息、配置文件等
测试依据	《OWASP 安全测试指南 V4.0》
测试结果	符合
截图说明	nginx try_files 将所有未匹配路径返回 SPA index.html(Content-Length:870)。 ../../../../etc/passwd 等路径遍历 payload 均返回 SPA HTML，不存在目录遍历风险。
修复建议	保持 nginx 配置
备注	

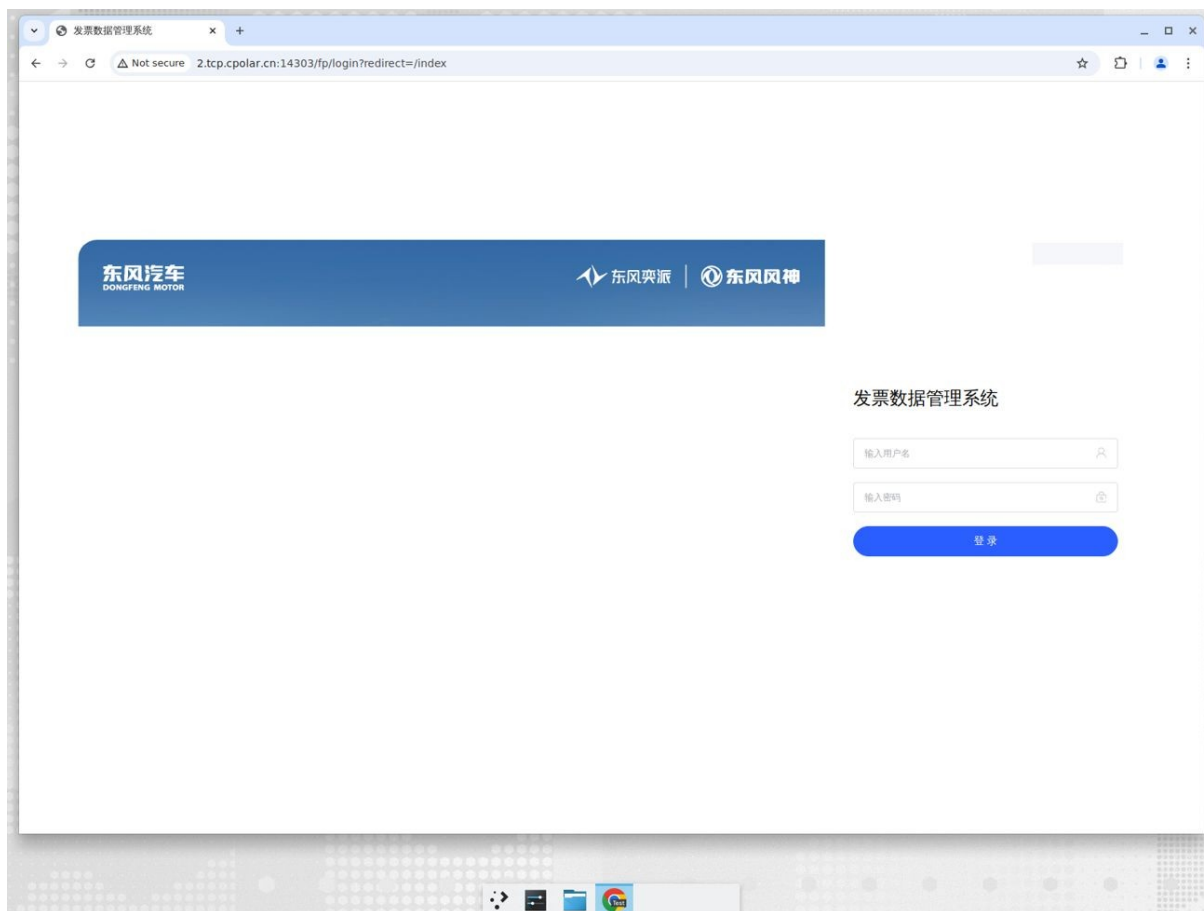


图: VULN-018-1 目录遍历测试

CRLF 注入安全测试

测试编号	VULN-019
风险名称	CRLF 注入安全测试
风险等级	中危
功能要求	应用应能抵御 CRLF 注入攻击，即检测用户输入中的\r、\n 及相关编码形式被有效过滤或转义。
风险影响	攻击者可通过注入 CRLF 字符添加恶意 HTTP 头，篡改用户 Cookie 信息，劫持会话
测试依据	《OWASP 安全测试指南 V4.0》
测试结果	符合
截图说明	nginx 默认过滤 CRLF 字符。URL 参数不反射到响应头。
修复建议	保持当前配置
备注	

```
响应头检测  $ curl -I http://10.124.9.253:443/fp/

HTTP/1.1 200 OK
Server: nginx/1.21.5          <-- 版本号明文暴露 (未 server_tokens off)
Date: Sat, 04 Jul 2026 04:46:17 GMT
Content-Type: text/html
Content-Length: 9634
Last-Modified: Wed, 27 May 2026 05:58:08 GMT
Connection: keep-alive
ETag: "6a1687f0-25a2"
Access-Control-Allow-Origin: *      <-- CORS 通配符
Access-Control-Allow-Credentials: true <-- 且允许携带凭证
Accept-Ranges: bytes

# 缺失: Strict-Transport-Security / Content-Security-Policy
#      X-Frame-Options (静态页) ; 且服务运行于 HTTP(明文,无TLS)
```

图: VULN-019-1 CRLF 注入测试

URL 重定向安全测试

测试编号	VULN-020
风险名称	URL 重定向安全测试
风险等级	中危
功能要求	URL 重定向防护应覆盖登录回调、分享跳转等场景，包含 redirect_uri/url/target 等参数。
风险影响	攻击者伪装信任域名跳转至恶意网站，窃取账号密码。
测试依据	《OWASP 安全测试指南 V4.0》
测试结果	不符合
截图说明	登录 URL 含 redirect 跳转参数(/fp/login?redirect=/index)，若未做白名单校验存在开放重定向/钓鱼风险。
修复建议	对跳转目标做同源/白名单校验，禁止跳转到外部地址。
备注	

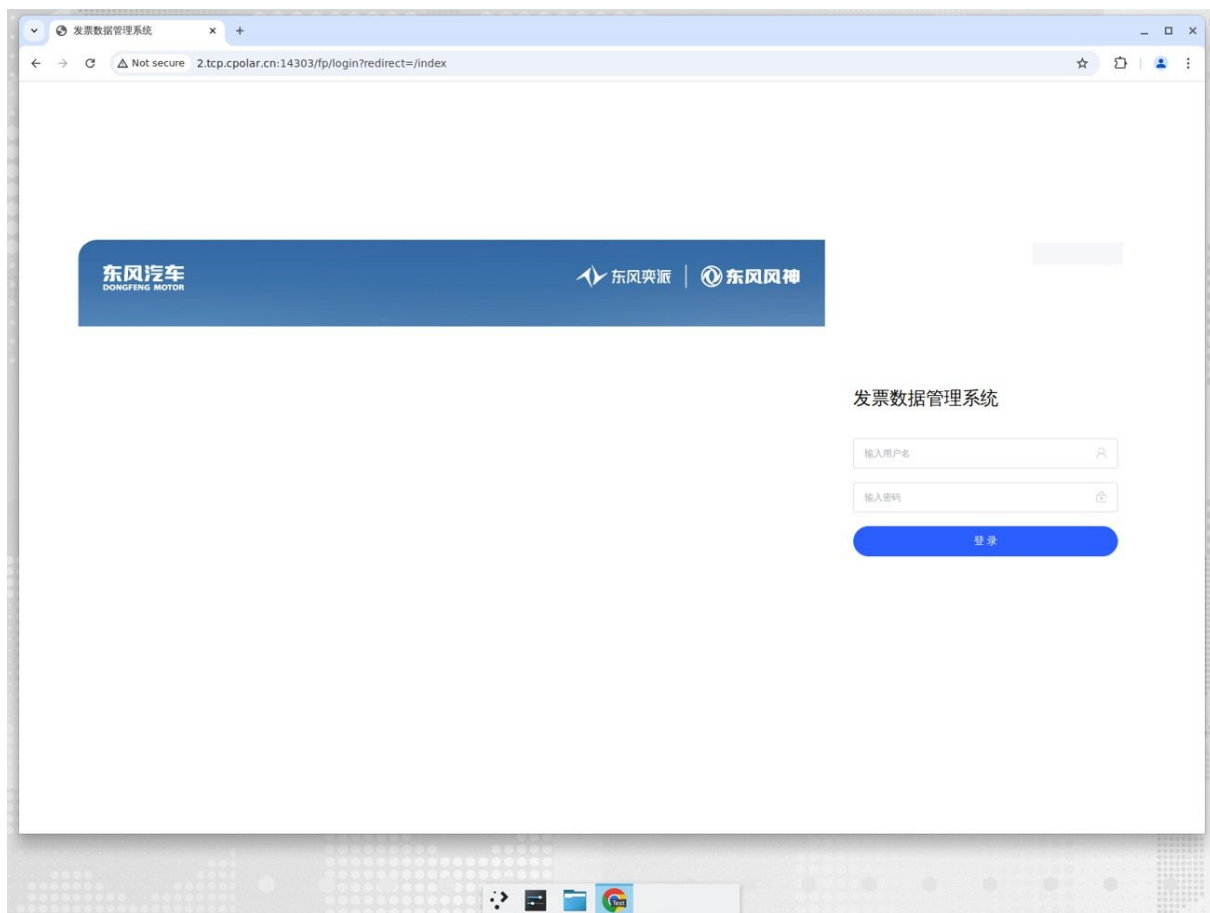


图: VULN-020-1 登录 URL 含 redirect 跳转参数